
Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
NÃO É BRUXARIA, É HANDSHAKE
TCP - Three Way Handshake
1. SYN
2. SYN-ACK
3. ACK
Cliente
Servidor
Flags Importantes
SYN Inicia conexão
ACK Confirma
FIN Finaliza conexão
RST Reseta conexão
UDP - User Datagram Protocol
Cliente
Servidor
Sem conexão
Rápido e leve
Sem garantia de entrega
Usado em DNS, VoIP, streaming, jogos, etc.
ICMP - Internet Control Message Protocol
$ ping 8.8.8.8
ICMP Echo Request →
ICMP Echo Reply ←
$ traceroute 8.8.8.8
1 192.168.1.1 1.2 ms
2 10.0.0.1 5.6 ms
3 172.16.0.1 12.4 ms
4 8.8.8.8 18.7 ms
Tipos ICMP
Echo Request (8)
Echo Reply (0)
Destination Unreachable (3)
Time Exceeded (11)
Redirect (5)
Protocolos Importantes
HTTP 80 Web (sem criptografia)
HTTPS 443 Web (criptografado)
DNS 53 Resolução de nomes
SMTP 25 E-mail (envio)
IMAP 143 E-mail (leitura)
POP3 110 E-mail (leitura)
SSH 22 Acesso remoto seguro
RDP 3389 Acesso remoto (Windows)
SMB 445 Compartilhamento de arquivos
LDAP 389 Diretório (Active Directory)
LDAPS 636 LDAP criptografado
Kerberos 88 Autenticação (AD)
NTLM - Autenticação (Windows)
FTP 21 Transferência de arquivos
SFTP 22 Transferência segura
SNMP 161 Monitoramento de rede
NTP 123 Sincronização de tempo
Firewall - Regra de Filtragem
Origem Destino Porta Ação
192.168.1.0/24 10.0.0.5 22 ALLOW
Any 203.0.113.10 3389 DENY
10.0.0.0/8 Any 80 ALLOW
192.168.1.50 8.8.8.8 53 ALLOW
Any Any 23 DENY
10.0.0.0/8 172.16.0.0/16 Any ALLOW
Proxy - Registro de Acesso
Data/Hora URL Usuário Categoria Ação
10:21:12 youtube.com ana Streaming DENY
10:22:01 github.com joao Dev ALLOW
10:23:45 malware.com - Malicioso DENY
10:24:10 chat.openai.com ana IA ALLOW
10:25:33 facebook.com carlos Redes Sociais DENY
VPN - Acessos Remotos
Usuário IP Público MFA País Status
ana 191.10.10.5 ✓ BR Conectado
carlos 203.0.113.25 ✓ BR Conectado
teste 45.67.89.10 ✗ RU Bloqueado
admin 198.51.100.4 ✓ US Conectado
mariana 177.12.34.56 ✓ BR Conectado
Wireshark - Captura de Pacotes
No. Time Source Destination Protocol Length Info
23 0.000000 192.168.1.50 8.8.8.8 DNS 78 Standard query A google.com
24 0.012345 8.8.8.8 192.168.1.50 DNS 122 Standard query response A 142.250.72.206
25 0.015678 192.168.1.50 142.250.72.206 TCP 74 52344 → 443 [SYN] Seq=0 Win=64240
26 0.028910 142.250.72.206 192.168.1.50 TCP 74 443 → 52344 [SYN, ACK] Seq=0 Ack=1
27 0.029915 192.168.1.50 142.250.72.206 TCP 66 52344 → 443 [ACK] Seq=1 Ack=1
0.123456 192.168.1.50 142.250.72.206 TLSv1.3 571 Client Hello
0.234567 142.250.72.206 192.168.1.50 TLSv1.3 1460 Server Hello
345678 192.168.1.50 142.250.72.206 HTTPS 1514 Application Data
tcpdump - Exemplo
$ tcpdump -i eth0 host 10.0.0.5
tcpdump: verbose output suppressed, use -v[v+]... for full protocol decode
listening on eth0, link-type EN10MB
12:34:56.123456 IP 192.168.1.50.54321 > 10.0.0.5.80: Flags [S], seq 12345, win 64240, length 0
12:34:56.123789 IP 10.0.0.5.80 > 192.168.1.50.54321: Flags [S.], seq 67890, ack 12346, win 65160, length 0
Fechamento do Módulo 1
Revisão dos principais conceitos
Exercícios práticos com PCAP
Cenários de investigação
Checklist de aprendizado
MÓDULO 1 CONCLUÍDO!
SEM PING NÃO HÁ PAZ
SOC N1
TCP e UDP
ICMP
PROTOCOLOS DE REDE
FIREWALL E PROXY
VPN
WIRESHARK E TCPDUMP
SEGURANÇA DE REDE
SÓ MAIS UM PACOTE
TCP/IP
Plano de hoje:
Ver handshake
Diferenciar TCP e UDP
Analisar PCAP
Não surtar com ICMP
Café (sempre)
ANTES DE CULPAR O HACKER, OLHA O FIREWALL
Módulo 1 — Fundamentos de Redes
Parte 2 de 2: do TCP ao Wireshark
Nesta parte: 1.11 TCP • 1.12 UDP • 1.13 ICMP • 1.14 Protocolos importantes • 1.15 Firewall • 1.16 Proxy • 1.17 VPN • 1.18 Wireshark e tcpdump • Fechamento completo do Módulo 1.
Anexo embutido: Lab_Modulo01_desafios.pcap — captura sintética com tráfego normal e oito cenários de investigação, anexada dentro deste documento na seção 1.18 (clique duas vezes no ícone).
Pré-requisitos: Módulo 0 e Módulo 1 — Parte 1. As figuras continuam a numeração da Parte 1 (1.12 em diante).

Sumário

Módulo 1 — Fundamentos de Redes (Parte 2) 4
Onde paramos e para onde vamos 4
1.11 TCP — Transmission Control Protocol 4
O que é, como funciona e por que existe 4
Campos do cabeçalho que interessam ao SOC 4
Flags TCP 5
Three-way handshake e encerramento 5
Portas de origem e destino: quem iniciou a conexão? 6
Conexão stateful e estados TCP 7
Como as varreduras aparecem 7
Logs relacionados 8
Comandos 9
1.12 UDP — User Datagram Protocol 9
Por que o UDP é traiçoeiro para o SOC 10
Logs relacionados 10
1.13 ICMP — Internet Control Message Protocol 11
TTL e ping 11
Traceroute 12
Abusos de ICMP (visão defensiva) 12
Comandos 13
1.14 Protocolos importantes 13
Web 14
Infraestrutura 15
E-mail 16
Acesso remoto e transferência 17
Identidade (aprofundado no Módulo 8) 18
Resumo dos protocolos 19
1.15 Firewall 20
Lendo um log de firewall 21
Exemplos de log 22
Perguntas padrão diante de um log de firewall 23
1.16 Proxy 24
Logs típicos 24
1.17 VPN 26
Investigando um login de VPN 27
1.18 Wireshark e tcpdump 28
A tela do Wireshark em 30 segundos 28
Filtros de exibição essenciais 28

Método de análise 29
tcpdump 30
Desafios com PCAP 30
Fechamento do Módulo 1 32
Ferramentas do módulo 32
Erros comuns 32
Falsos positivos comuns 32
Exercícios da Parte 2 33
Laboratório integrado do Módulo 1 34
Perguntas de entrevista — Parte 2 34
Checklist de domínio do Módulo 1 36
Resumo do Módulo 1 37
Respostas comentadas — exercícios da Parte 2 37
Respostas dos desafios com PCAP 38
Próximo módulo 40

Se o sumário aparecer vazio, clique com o botão direito sobre ele no Word e escolha "Atualizar campo".

Módulo 1 — Fundamentos de Redes (Parte 2)

Onde paramos e para onde vamos

Na Parte 1 você aprendeu **onde** os pacotes vão: endereçamento, ARP, VLAN, roteamento, NAT, DNS e DHCP. Agora vamos aprender **como** a conversa acontece (TCP, UDP, ICMP), **quais idiomas** os sistemas falam (os protocolos), e **quem fica no meio olhando e registrando** (firewall, proxy, VPN). No fim, você vai abrir uma captura de verdade no Wireshark e investigar oito cenários.

> 🎯 **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Desta parte, o que mais cai no dia a dia e na entrevista:
>
> - Ler `10.0.0.5:51523 → 172.16.1.10:443` e dizer **quem iniciou** e **qual serviço** foi acessado.
> - Reconhecer pelos flags se uma conexão **completou** ou foi só **tentativa** (SYN sem resposta, RST).
> - Saber as portas e o "jeito de ser atacado" dos protocolos mais comuns: RDP, SMB, SSH, DNS, HTTP(S), LDAP, Kerberos.
> - Ler um log de firewall campo a campo e saber a próxima pergunta.
> - Investigar um login de VPN além do "usuário e senha estavam certos".
> - Usar meia dúzia de filtros do Wireshark sem pânico.

1.11 TCP — Transmission Control Protocol

O que é, como funciona e por que existe

O **TCP** é o protocolo de transporte que garante que os dados cheguem **completos, na ordem certa e sem duplicação**. A internet por baixo é "melhor esforço": pacotes se perdem, chegam fora de ordem ou duplicados. O TCP resolve isso numerando cada byte (números de sequência), confirmando o recebimento (ACK), retransmitindo o que se perde e controlando a velocidade para não afogar o destino nem a rede.

Ele é **orientado a conexão**: antes de enviar dados, os dois lados combinam a conversa (handshake) e, ao final, encerram formalmente. Cada conexão é identificada pela **5-tupla**: protocolo, IP de origem, porta de origem, IP de destino, porta de destino. É exatamente essa 5-tupla que aparece em logs de firewall, NetFlow e EDR.

Campos do cabeçalho que interessam ao SOC

Campo	Para que serve	Interesse para o SOC
Porta de origem	Identifica o processo que enviou.	No cliente, normalmente uma porta **efêmera** alta e aleatória.
Porta de destino	Identifica o serviço desejado.	Indica o serviço **esperado** (443, 3389, 445...).
Número de sequência (seq)	Posição do primeiro byte deste segmento no fluxo.	Usado pelo Wireshark para remontar a conversa.
Número de confirmação (ack)	Próximo byte esperado do outro lado.	Mostra se o destino está recebendo.
Flags	Controle: SYN, ACK, FIN, RST, PSH, URG.	Revelam abertura, encerramento, recusa e varreduras.

Campo	Para que serve	Interesse para o SOC
Janela (window)	Quantos bytes o receptor aceita antes de confirmar.	Janela zero repetida indica destino sobrecarregado.

Flags TCP

Flag	Nome	Significado	Leitura de SOC
SYN	Synchronize	Pedido de abertura; sincroniza números de sequência.	Muitos SYN sem conclusão = varredura ou SYN flood.
ACK	Acknowledgment	Confirma recebimento; presente em quase todo segmento após o handshake.	SYN+ACK = "porta aberta, aceito".
FIN	Finish	Encerramento educado: "terminei de enviar".	Encerramento normal de sessão.
RST	Reset	Encerramento abrupto: porta fechada, conexão recusada ou abortada.	Muitos RST de um destino = muitas portas fechadas testadas.
PSH	Push	Entregar imediatamente à aplicação.	Normal em segmentos com dados.
URG	Urgent	Dados urgentes (raríssimo hoje).	Combinações estranhas (FIN+PSH+URG = "Xmas scan") indicam varredura.

Three-way handshake e encerramento

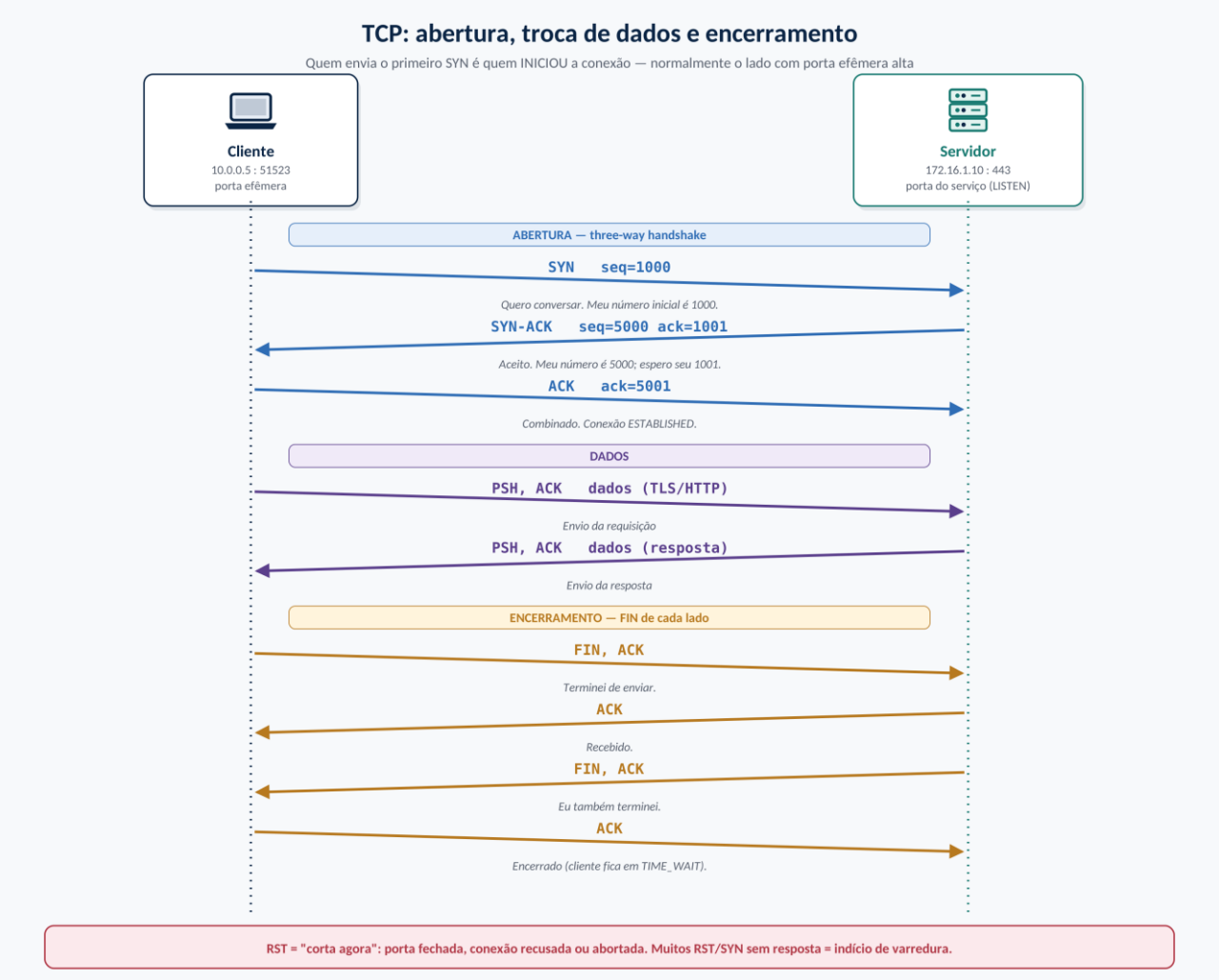


Figura 1.12 — Abertura (SYN, SYN-ACK, ACK), troca de dados e encerramento com FIN

1. **SYN** — o cliente escolhe um número de sequência inicial e pede para abrir a conexão.
2. **SYN-ACK** — o servidor aceita, informa seu próprio número inicial e confirma o do cliente.
3. **ACK** — o cliente confirma. A conexão está **ESTABLISHED**. Só agora os dados começam.

O encerramento normal usa **FIN** de cada lado (quatro segmentos, às vezes três). O **RST** é o "desliga na cara": usado quando não há serviço na porta, quando um lado quer abortar ou quando um firewall/IPS derruba a sessão ativamente.

Portas de origem e destino: quem iniciou a conexão?

Esta é uma das perguntas mais importantes da sua vida de N1. Considere:

```
Cliente:  10.0.0.5:51523
Servidor: 172.16.1.10:443

Pacote 1: 10.0.0.5:51523  → 172.16.1.10:443    [SYN]
Pacote 2: 172.16.1.10:443 → 10.0.0.5:51523     [SYN, ACK]
Pacote 3: 10.0.0.5:51523  → 172.16.1.10:443    [ACK]
```

- **Quem iniciou:** `10.0.0.5`, porque enviou o primeiro **SYN**. É o cliente.
- **Serviço acessado:** porta **443** (HTTPS) em `172.16.1.10`, que estava em estado **LISTEN** esperando conexões.

- **Porta 51523:** porta **efêmera**, escolhida aleatoriamente pelo sistema do cliente só para essa conversa. Ela não diz nada sobre o serviço.
- **Na volta**, origem e destino se invertem (`172.16.1.10:443 → 10.0.0.5:51523`). Se você olhar apenas um pacote de resposta isolado, pode achar que o servidor "conectou no cliente na porta 51523". Não conectou.

Sistema	Faixa efêmera padrão
Windows moderno (Vista em diante)	49152 a 65535
Linux (padrão)	32768 a 60999 (ver `/proc/sys/net/ipv4/ip_local_port_range`)
Firewalls com PAT	Escolhem sua própria faixa na tradução (a porta pública não é a porta original)

> **DICA**
>
> Regra prática para logs que não mostram flags: **porta baixa e conhecida de um lado + porta alta do outro** → o lado da porta baixa é quase sempre o servidor, e o da porta alta, o cliente.
>
> Exceções existem (serviços em portas altas como 8443, 5985, bancos de dados em 1433), então quando a direção importa, confirme pelo log de sessão do firewall (que registra quem abriu), pelo EDR ou pelo PCAP.

Conexão stateful e estados TCP

Stateful significa que o equipamento (firewall, sistema operacional) **lembra** das conexões abertas. Um firewall stateful permite a resposta de uma conexão que a rede interna iniciou sem precisar de uma regra de entrada para ela, porque a resposta pertence a uma sessão conhecida. Isso é a base de praticamente todo firewall moderno.

Estado (netstat)	Significado	Leitura de SOC
LISTEN	Serviço esperando conexões nessa porta.	Que portas este host expõe? Alguma inesperada (ex.: 4444, 8888)?
SYN_SENT	Enviou SYN e aguarda resposta.	Muitos SYN_SENT para vários destinos = tentativa de varredura ou C2 sem resposta.
SYN_RECEIVED	Recebeu SYN, respondeu SYN-ACK, aguarda ACK.	Muitos ao mesmo tempo = possível SYN flood contra o host.
ESTABLISHED	Conexão ativa.	Com quem este host está falando agora? Qual processo?
FIN_WAIT / CLOSE_WAIT	Em encerramento.	Muitos CLOSE_WAIT costumam ser bug de aplicação, não ataque.
TIME_WAIT	Conexão encerrada; aguardando pacotes atrasados.	Normal em grande volume em servidores web.

Como as varreduras aparecem

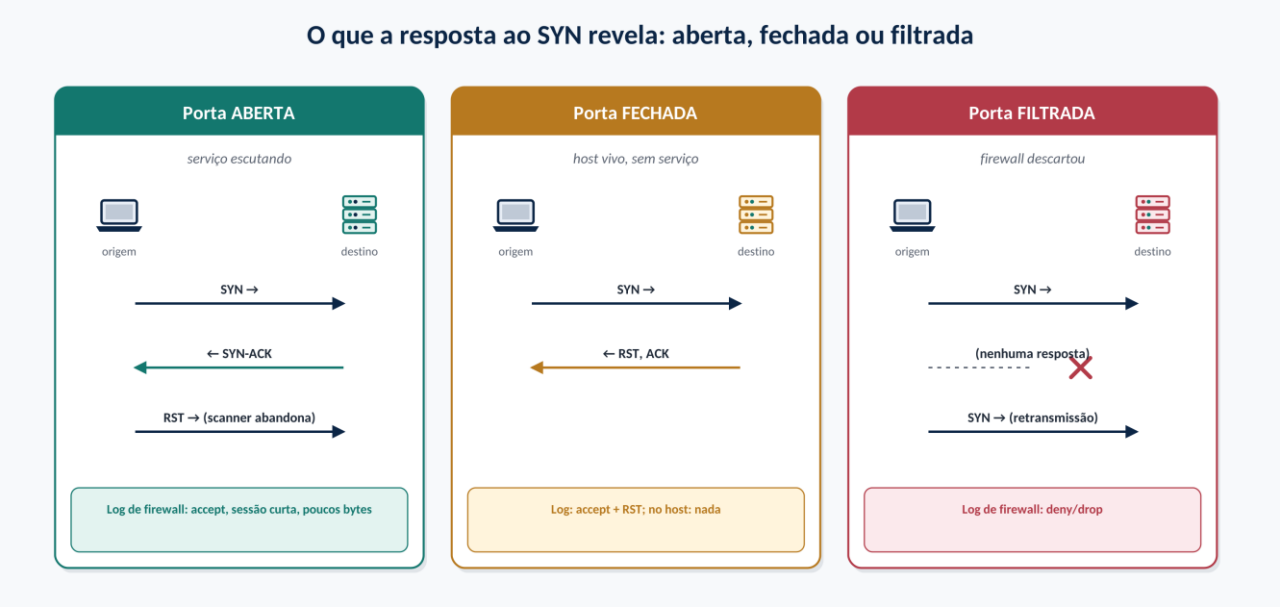


Figura 1.13 — Resposta ao SYN: porta aberta, fechada ou filtrada

Uma varredura de portas é basicamente enviar SYN para muitas portas e observar a resposta. Do lado defensivo, os sinais são: **um mesmo IP de origem** tocando **muitas portas** de um destino (varredura vertical) ou **a mesma porta** em **muitos destinos** (varredura horizontal, típica de worms e de quem procura RDP ou SMB expostos), em pouco tempo, com sessões curtíssimas e poucos bytes.

Logs relacionados

```
# Firewall (sessão completa)
2026-10-10T09:14:02-03:00 FW-CORE action=allow src=10.10.0.87:51523 dst=172.16.1.10:443
proto=tcp
  bytes_sent=2140 bytes_recv=58211 duration=31s tcp_flags=SYN,ACK,PSH,FIN reason=tcp-fin

# Firewall (tentativa recusada pelo destino)
2026-10-10T09:15:10-03:00 FW-CORE action=allow src=10.10.0.66:41877 dst=10.20.0.10:23
proto=tcp
  bytes_sent=60 bytes_recv=54 duration=0s reason=tcp-rst-from-server

# Zeek conn.log (conn_state resume a história da conexão)
id.orig_h=10.10.0.66 id.orig_p=41877 id.resp_h=10.20.0.10 id.resp_p=23 proto=tcp
conn_state=REJ history=Sr
id.orig_h=10.10.0.87 id.orig_p=51523 id.resp_h=172.16.1.10 id.resp_p=443 proto=tcp
conn_state=SF history=ShADadFf
id.orig_h=10.10.0.66 id.orig_p=41990 id.resp_h=10.20.0.99 id.resp_p=445 proto=tcp
conn_state=S0 history=S
#  SF = fechada normalmente | REJ = recusada (RST) | S0 = SYN sem resposta | RSTO/RSTR =
abortada

# Sysmon Event ID 3 (conexão de rede COM o processo)
EventID: 3  Image: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe  User:
CORP\jsilva
Protocol: tcp  Initiated: true  SourceIp: 10.10.0.87  SourcePort: 52811  DestinationIp:
192.0.2.66  DestinationPort: 443
```

NA VIDA REAL

> No Sysmon 3, o campo `Initiated: true` responde de bandeja "quem iniciou". O Zeek responde com `id.orig_h` (originador). O firewall responde com src. Três ferramentas, três nomes para a mesma pergunta.
>
> Decorar o nome do campo em cada ferramenta é inútil. Entender a pergunta é o que permite achar o campo em qualquer uma.

Comandos

```
# Windows
netstat -ano                          # conexões, estados e PID
netstat -anob                         # + nome do executável (requer admin)
netstat -ano | findstr ESTABLISHED
netstat -ano | findstr :3389          # quem está usando/ouvindo RDP
Get-NetTCPConnection -State Established | Select
LocalAddress,LocalPort,RemoteAddress,RemotePort,OwningProcess
Get-NetTCPConnection -State Listen
Get-Process -Id 4312                  # descobrir o processo do PID
Test-NetConnection 172.16.1.10 -Port 443   # testar se a porta responde

# Linux
ss -tunap                             # TCP+UDP, numérico, todos, com processo
ss -tlnp                              # só portas TCP em LISTEN
ss -tn state established
lsof -i :443                          # quem usa a porta 443
nc -zv 172.16.1.10 443                # testar porta (no seu lab)
```

Leitura de SOC	
O que procuro	Quem iniciou (primeiro SYN, campo originador, `Initiated`), qual serviço (porta de destino), se completou (flags, bytes, duração, conn_state) e qual processo (EDR/Sysmon).
Pode ser benigno	Scanner de vulnerabilidades autorizado; monitoramento (Zabbix, PRTG) testando portas; aplicações com muitas conexões curtas; RST de balanceadores encerrando sessões ociosas.
Pode ser suspeito	Host de usuário tocando dezenas de portas ou dezenas de hosts em minutos; conexões estabelecidas para portas altas incomuns em IP externo; processo não esperado (Office, script, binário em AppData) abrindo conexões.
Próximo passo	Contar destinos e portas distintas por origem na janela; checar se alguma tentativa virou sessão com volume; identificar o processo; verificar se a origem é ativo autorizado (CMDB, lista de scanners).
Quando escalo	Varredura interna a partir de host que não é scanner autorizado; varredura seguida de conexões bem-sucedidas a SMB/RDP/WinRM; conexões persistentes de processo suspeito para destino externo.

1.12 UDP — User Datagram Protocol

O **UDP** é o primo despachado do TCP: **sem conexão, sem handshake, sem confirmação, sem retransmissão**. O remetente simplesmente envia o datagrama e segue a vida. Se chegar, chegou. Parece pior, mas é exatamente o que se quer em consultas curtas (DNS), em descoberta na rede local (DHCP) e em

tráfego em tempo real (voz, vídeo, jogos), onde esperar uma retransmissão é pior do que perder um pedaço.

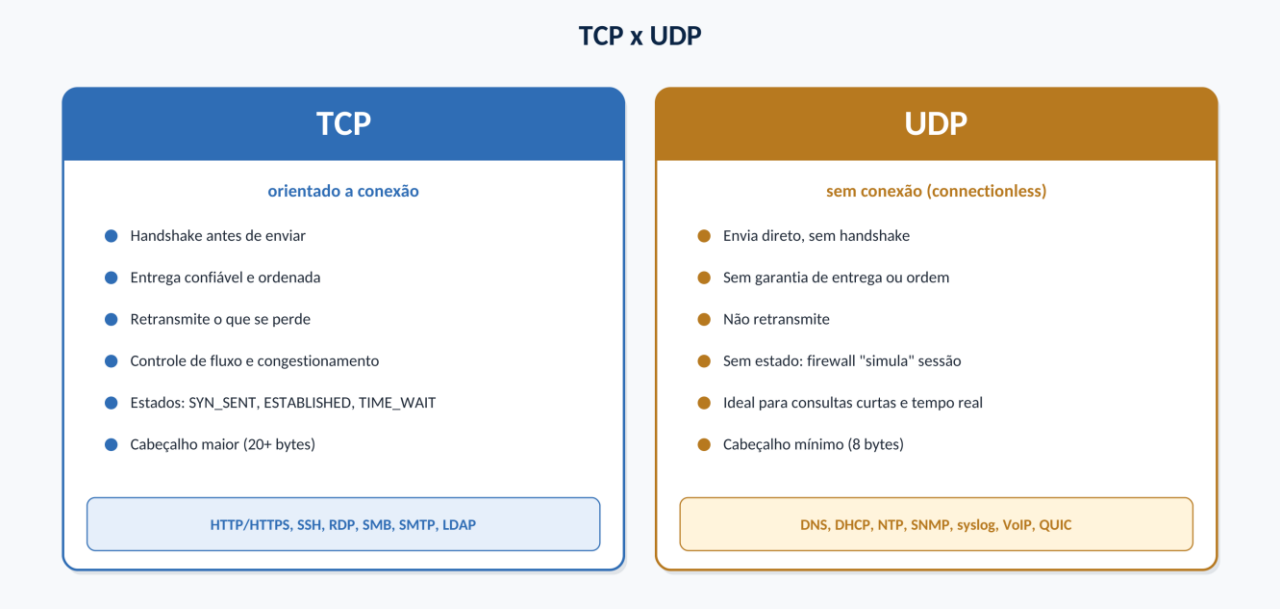


Figura 1.14 — Comparação entre TCP e UDP

Aspecto	TCP	UDP
Conexão	Handshake antes de enviar	Nenhuma
Confiabilidade	Confirma e retransmite	Sem garantia
Ordem	Garantida	Não garantida
Estado no firewall	Sessão real com início e fim	Pseudo-sessão por tempo (timeout)
Cabeçalho	20 bytes ou mais	8 bytes
Exemplos	HTTP(S), SSH, RDP, SMB, SMTP, LDAP	DNS, DHCP, NTP, SNMP, syslog, VoIP, QUIC (HTTP/3), IKE

Por que o UDP é traiçoeiro para o SOC

- **Não há "conexão estabelecida" para provar sucesso.** Você vê que o datagrama saiu; não tem flag dizendo que o outro lado aceitou. Procure respostas no sentido inverso.
- **Varredura UDP é ambígua:** porta fechada costuma responder ICMP "port unreachable"; porta aberta muitas vezes não responde nada; porta filtrada também não. Ferramentas ficam no "open|filtered".
- **Origem forjável:** como não há handshake, é fácil enviar UDP com IP de origem falso. Isso viabiliza ataques de **amplificação/reflexão** (DNS, NTP, SSDP, memcached): pequenas consultas com origem forjada geram respostas enormes para a vítima.
- **Canais encobertos:** DNS sobre UDP é o meio preferido de tunelamento justamente por quase sempre estar liberado.
- **QUIC (UDP/443):** navegadores modernos usam HTTP/3 sobre UDP. Proxies e alguns firewalls não inspecionam QUIC; muitas empresas bloqueiam UDP/443 para forçar o tráfego por TCP/443, onde há inspeção.

Logs relacionados

```
# Firewall: DNS direto para resolver externo (contornando o DNS corporativo)
action=allow src=10.10.0.140:61022 dst=8.8.8.8:53 proto=udp bytes_sent=74 bytes_recv=90
app=dns

# Firewall: possível reflexão NTP (servidor interno respondendo grandes volumes para fora)
action=allow src=10.50.0.5:123 dst=203.0.113.9:80 proto=udp bytes_sent=48210311 packets=103002

# Zeek conn.log de UDP
id.orig_h=10.10.0.140 id.orig_p=61022 id.resp_h=8.8.8.8 id.resp_p=53 proto=udp service=dns
conn_state=SF
```

Leitura de SOC	
O que procuro	Para onde vai o UDP (DNS e NTP só para servidores autorizados?), volume por fluxo, respostas do outro lado, uso de UDP/443 (QUIC), portas UDP incomuns.
Pode ser benigno	DNS para o resolver interno; NTP para servidores de hora definidos; syslog para o coletor; VoIP/videoconferência para faixas de SaaS conhecidas.
Pode ser suspeito	Estação falando DNS direto com resolver externo; servidor interno enviando enormes volumes UDP para fora (reflexão); UDP para portas altas aleatórias em países/ASNs incomuns; DNS com payloads grandes.
Próximo passo	Verificar a política de egress (o que deveria ser permitido), identificar o processo no EDR, quantificar volume e duração, buscar padrão em outros hosts.
Quando escalo	Servidor da empresa participando de amplificação, tunelamento confirmado, ou volume de saída atípico de host crítico.

1.13 ICMP — Internet Control Message Protocol

O **ICMP** é o protocolo de **mensagens de controle e erro** da camada 3. Não tem portas. Ele avisa coisas como "destino inalcançável", "TTL expirou no caminho" ou "estou vivo". Ferramentas como **ping** e **traceroute** são construídas sobre ele.

Tipo	Código	Nome	Uso / leitura de SOC
8	0	Echo Request	O "ping" enviado. Muitos para muitos destinos = ping sweep (descoberta de hosts).
0	0	Echo Reply	Resposta ao ping: "estou vivo".
3	0–15	Destination Unreachable	Código 3 = porta inalcançável (UDP fechado); código 13 = bloqueado administrativamente.
11	0	Time Exceeded	TTL zerou no caminho. Base do traceroute.
5	—	Redirect	"Use outro gateway". Raro e abusável; normalmente desativado.

TTL e ping

O **TTL** (Time To Live) é um contador no cabeçalho IP decrementado a cada roteador. Ao chegar a zero, o pacote é descartado e o roteador envia ICMP Time Exceeded à origem. Isso evita pacotes circulando para sempre em loops.

Curiosidade útil: sistemas operacionais usam TTL inicial diferente, o que dá uma pista (não prova) do SO do outro lado. **Windows: 128. Linux/macOS: 64. Muitos equipamentos de rede: 255.** Um ping respondido com TTL 127 veio, provavelmente, de um Windows a um salto de distância.

```
C:\> ping 10.20.0.10
Resposta de 10.20.0.10: bytes=32 tempo=1ms TTL=127

$ ping -c 3 8.8.8.8
64 bytes from 8.8.8.8: icmp_seq=1 ttl=117 time=12.4 ms
```

Traceroute

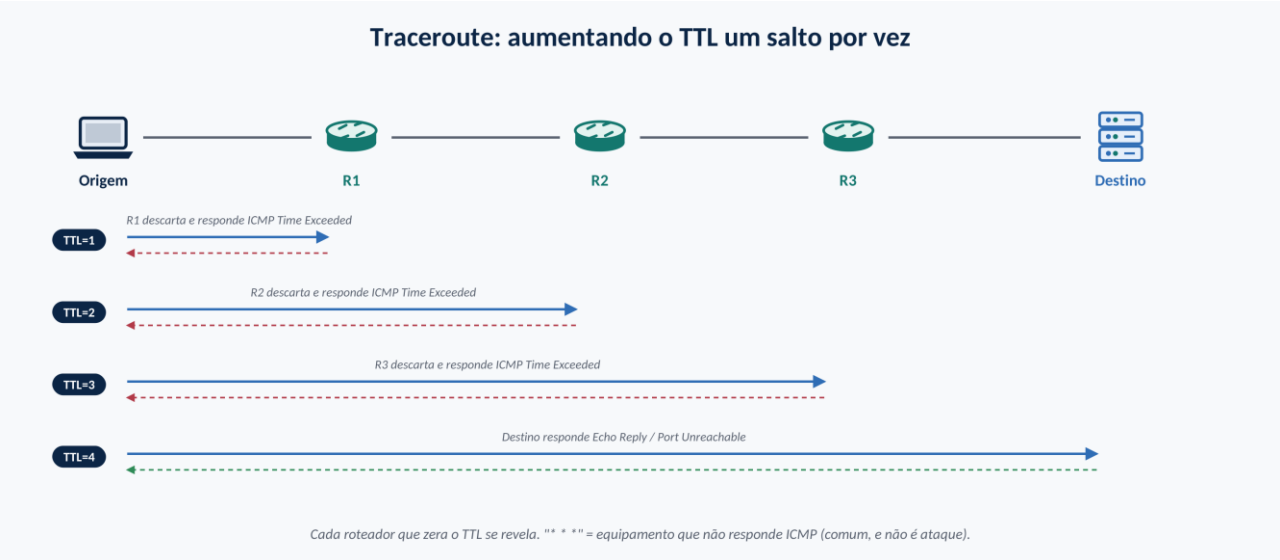


Figura 1.15 — Traceroute: cada TTL revela um salto do caminho

O **traceroute** envia pacotes com TTL 1, 2, 3... Cada roteador que zera o TTL responde com Time Exceeded e se revela. No Windows (`tracert`) usa ICMP; no Linux (`traceroute`) usa UDP por padrão (`-I` para ICMP, `-T` para TCP). Linhas com `* * *` significam que aquele salto não respondeu, o que é comum e quase nunca é ataque.

Abusos de ICMP (visão defensiva)

Técnica	Sinal	Falso positivo comum
Ping sweep (descoberta)	Um host enviando Echo Request para muitos IPs sequenciais em segundos.	Ferramentas de monitoramento e inventário; scanner autorizado.
ICMP tunneling	Echo Request/Reply com payload grande e variável, em volume constante para um mesmo destino externo.	Ferramentas de teste de MTU/latência com payload grande.
Flood / smurf	Volume massivo de ICMP contra um alvo; respostas a broadcast.	Testes de carga mal comunicados.
Reconhecimento por traceroute	Time Exceeded em sequência vindo de fora para dentro.	Diagnóstico legítimo de parceiros/provedores.

```
# Firewall: ping sweep interno
02:00:01 src=10.10.0.66 dst=10.20.0.1  proto=icmp type=8 action=allow
```

```
02:00:01 src=10.10.0.66 dst=10.20.0.2  proto=icmp type=8 action=allow
02:00:01 src=10.10.0.66 dst=10.20.0.3  proto=icmp type=8 action=allow
... (254 destinos em 9 segundos)

# Zeek conn.log — ICMP com payload anormal
id.orig_h=10.10.0.77 id.resp_h=203.0.113.50 proto=icmp orig_bytes=980 resp_bytes=980
orig_pkts=4120 duration=3600
```

Comandos

```
ping 10.20.0.10              # Windows (4 pacotes)
ping -n 1 -w 500 10.20.0.10  # Windows: 1 pacote, timeout 500 ms
ping -c 4 10.20.0.10         # Linux
tracert -d 8.8.8.8           # Windows
traceroute -I 8.8.8.8        # Linux, via ICMP
Test-Connection 10.20.0.10 -Count 2   # PowerShell
```

Leitura de SOC	
O que procuro	Volume e distribuição de Echo Request por origem, tamanho dos payloads, destinos externos com ICMP contínuo.
Pode ser benigno	Monitoramento de disponibilidade (pings periódicos e regulares para os mesmos alvos), troubleshooting pontual, traceroute de diagnóstico.
Pode ser suspeito	Host de usuário fazendo varredura ICMP de sub-redes inteiras; ICMP com payload grande e constante para IP externo; varredura ICMP seguida de varredura de portas nos hosts que responderam.
Próximo passo	Identificar origem (CMDB, EDR), correlacionar com varredura TCP/UDP do mesmo host, verificar processo responsável.
Quando escalo	Descoberta de rede a partir de host não autorizado (comum em fase de reconhecimento pós-invasão) ou indício de tunelamento ICMP.

1.14 Protocolos importantes

Não decore uma tabela de portas. Para cada protocolo, entenda **o que ele faz**, **como é abusado**, **que log o mostra** e **que pergunta você faria**. A porta é só o endereço da casa; o que importa é o que acontece lá dentro.

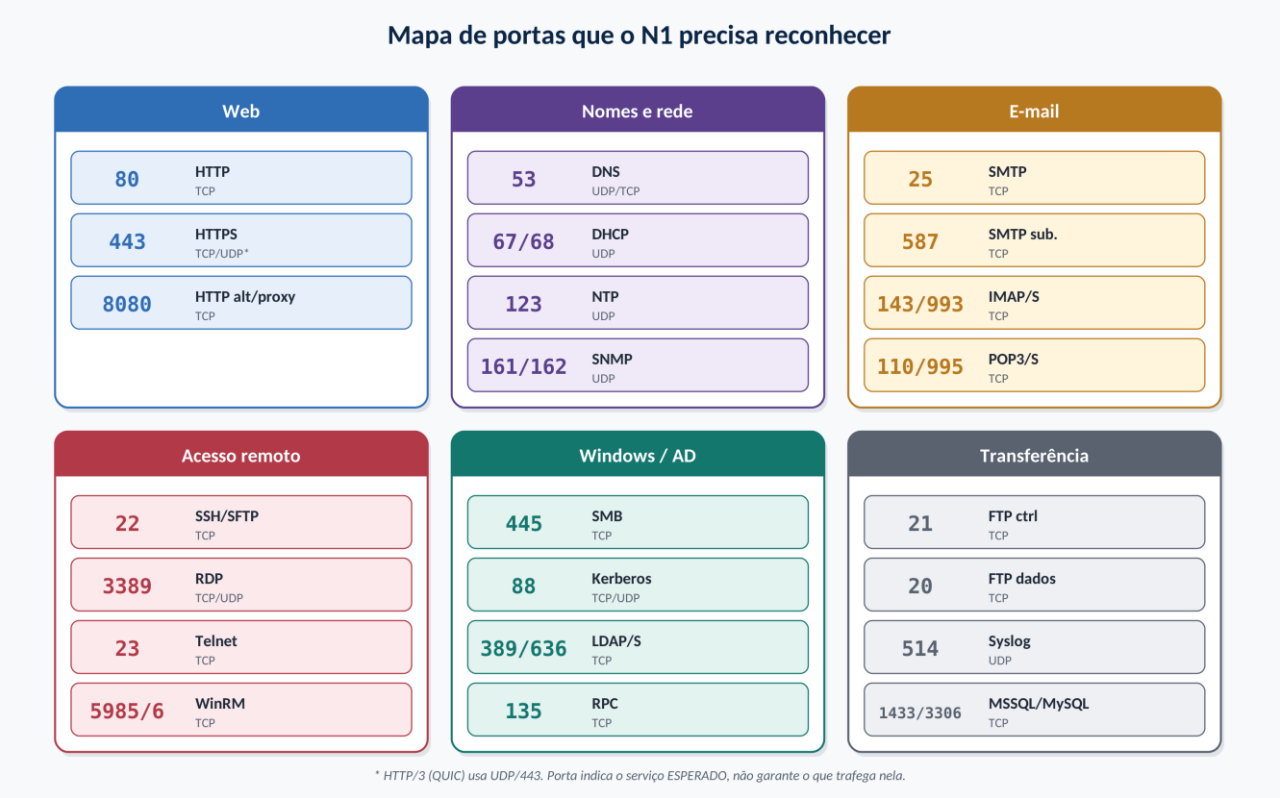


Figura 1.16 — As portas mais frequentes em investigações, agrupadas por função

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Porta indica o serviço **esperado**, não o real. Nada impede um atacante de rodar SSH na porta 443 ou um C2 HTTP na porta 53.
>
> É por isso que NGFWs identificam **aplicação** (app-id) além da porta, e é por isso que "a porta é 443, então é navegação" não é análise.

Web

HTTP — porta 80 (também 8080, 8000) • TCP

Aspecto	Descrição
Função	Transferência de páginas, APIs e arquivos em **texto claro**. Métodos (GET, POST, PUT, DELETE), códigos de status (2xx sucesso, 3xx redirecionamento, 4xx erro do cliente, 5xx erro do servidor), cabeçalhos (Host, User-Agent, Referer, Cookie).
Como aparece em ataques	Credenciais e cookies trafegando em claro; download de payloads; C2 simples; exploração de aplicações web (SQLi, XSS, traversal); user-agents de ferramentas (curl, python-requests, sqlmap).
Logs relacionados	Proxy, WAF, logs do servidor web (IIS, Apache, Nginx), Zeek http.log, NGFW.
Perguntas de investigação	Qual URL, método e código? Quem pediu (usuário/host)? Qual user-agent? Houve download de executável? O destino é conhecido?

HTTPS — porta 443 • TCP (e UDP/443 com HTTP/3)

Aspecto	Descrição
Função	HTTP dentro de **TLS**: confidencialidade e integridade. O conteúdo fica cifrado; ficam visíveis IPs, portas, **SNI** (nome pedido), certificado e volume.
Como aparece em ataques	A maior parte do malware moderno usa HTTPS para C2 e exfiltração, misturando-se à navegação; phishing com certificados válidos gratuitos; domínios recém-criados com TLS.
Logs relacionados	Proxy com inspeção TLS (URL completa), NGFW (SNI, categoria), Zeek ssl.log (SNI, certificado, JA3/JA4), EDR (processo).
Perguntas de investigação	Qual SNI e categoria? Certificado válido, autoassinado ou recém-emitido? Qual processo abriu a conexão? Padrão de conexões regulares (beaconing)? Volume de saída anormal?

Infraestrutura

DNS — porta 53 (DoT 853, DoH 443) • UDP e TCP

Aspecto	Descrição
Função	Resolução de nomes (detalhado na seção 1.9 da Parte 1).
Como aparece em ataques	DGA, tunneling, fast flux, domínios recém-criados, DNS direto para resolvers externos, DoH contornando o resolver corporativo.
Logs relacionados	Resolver interno, Sysmon 22, Zeek dns.log, firewall/NGFW, proteção DNS (filtro de domínios).
Perguntas de investigação	Que processo resolveu? Domínio novo ou raro? NXDOMAIN em massa? A consulta virou conexão? Outros hosts consultaram?

DHCP — porta 67 (servidor) / 68 (cliente) • UDP

Aspecto	Descrição
Função	Configuração automática de IP (seção 1.10).
Como aparece em ataques	Rogue DHCP (MitM), starvation, dispositivo não gerenciado obtendo IP.
Logs relacionados	Servidor DHCP, DHCP snooping no switch, NAC.
Perguntas de investigação	Quem tinha o IP no horário? Hostname e MAC condizem com ativo conhecido? Há servidor DHCP não autorizado?

NTP — porta 123 • UDP

Aspecto	Descrição
Função	Sincronização de relógio. Fundamental: Kerberos falha com diferença de alguns minutos e a correlação de logs depende de horário correto.
Como aparece em ataques	Amplificação/reflexão (comando monlist em servidores antigos); manipulação de horário para atrapalhar correlação ou validade de certificados.
Logs relacionados	Firewall, logs do serviço de tempo (Windows Time, chrony).

Aspecto	Descrição
Perguntas de investigação	Os hosts sincronizam com as fontes oficiais? Há servidor NTP interno respondendo para a internet? Por que esse host está com relógio errado?

SNMP — porta 161 (consultas) / 162 (traps) • UDP

Aspecto	Descrição
Função	Monitoramento e gerência de equipamentos (switches, roteadores, impressoras). v1/v2c usam **community strings** em texto claro (frequentemente "public"/"private"); v3 tem autenticação e cifra.
Como aparece em ataques	Coleta de informações com community padrão; alteração de configuração com community de escrita; amplificação.
Logs relacionados	Firewall, logs do equipamento, plataforma de monitoramento.
Perguntas de investigação	A origem é o servidor de monitoramento oficial? Qual versão? Alguém de fora consultou SNMP? Houve SET (escrita)?

ICMP — porta sem porta • camada 3

Aspecto	Descrição
Função	Controle e erro (seção 1.13).
Como aparece em ataques	Ping sweep, tunneling, flood.
Logs relacionados	Firewall, Zeek, IDS.
Perguntas de investigação	Quem varreu o quê? Payload anormal? Seguido de varredura de portas?

E-mail

SMTP — porta 25 (entre servidores), 587 (envio autenticado), 465 (SMTPS) • TCP

Aspecto	Descrição
Função	Envio e transporte de e-mail entre servidores e de clientes para servidores.
Como aparece em ataques	Phishing e spoofing de remetente; estação enviando SMTP direto para a internet (malware de spam); exfiltração por e-mail; open relay.
Logs relacionados	Gateway de e-mail, servidor de e-mail (Exchange/M365 message trace), firewall.
Perguntas de investigação	Quem enviou, para quem, de qual IP? SPF/DKIM/DMARC passaram? Por que uma estação está falando porta 25 com a internet?

IMAP — porta 143 / 993 (IMAPS) • TCP

Aspecto	Descrição
Função	Leitura de e-mail mantendo as mensagens no servidor (sincronização entre dispositivos).
Como aparece em ataques	Brute force e password spraying (protocolos "legados" frequentemente sem MFA); acesso de clientes incomuns; download em massa da caixa.

Aspecto	Descrição
Logs relacionados	Logs de autenticação do servidor/IdP (ex.: logins com protocolo IMAP no M365), firewall.
Perguntas de investigação	De qual IP e país? Cliente/agente usado? O usuário usa IMAP normalmente? Autenticação legada deveria estar bloqueada?

POP3 — porta 110 / 995 (POP3S) • TCP

Aspecto	Descrição
Função	Download de e-mail (tradicionalmente apagando do servidor).
Como aparece em ataques	Mesmos abusos do IMAP: spraying e coleta de caixas com autenticação legada.
Logs relacionados	Logs de autenticação do servidor de e-mail/IdP.
Perguntas de investigação	Alguém ainda usa POP3 legitimamente? Login de origem incomum?

Acesso remoto e transferência

SSH — porta 22 • TCP

Aspecto	Descrição
Função	Acesso remoto seguro a terminal (principalmente Linux e equipamentos de rede), tunelamento e transferência (SCP/SFTP).
Como aparece em ataques	Brute force contra servidores expostos; uso de chaves roubadas; túneis SSH para contornar firewall (port forwarding); movimentação lateral em ambientes Linux.
Logs relacionados	`/var/log/auth.log` ou `/var/log/secure`, journald, firewall, EDR Linux.
Perguntas de investigação	Senha ou chave? De qual IP? Login de root direto? Muitas falhas antes do sucesso? Sessão longa com túnel? Origem é bastion autorizado?

RDP — porta 3389 • TCP (e UDP)

Aspecto	Descrição
Função	Área de trabalho remota do Windows.
Como aparece em ataques	Um dos vetores mais comuns de ransomware quando exposto à internet: brute force, credenciais vazadas, depois movimentação lateral interna por RDP.
Logs relacionados	Windows Security 4624/4625 com **Logon Type 10**, logs TerminalServices (RemoteConnectionManager 1149, LocalSessionManager 21/24/25), firewall, EDR.
Perguntas de investigação	Está exposto à internet? Quem conectou, de onde, quando? A origem interna é jump server autorizado? Um usuário comum fazendo RDP em servidores? Sessões fora de horário?

SMB — porta 445 (139 legado com NetBIOS) • TCP

Aspecto	Descrição
Função	Compartilhamento de arquivos e impressoras no Windows; também transporte para administração remota (named pipes, PsExec, serviços remotos).

Aspecto	Descrição
Como aparece em ataques	Movimentação lateral (PsExec, criação remota de serviços), propagação de worms e ransomware, criptografia de compartilhamentos, exfiltração, relay de NTLM.
Logs relacionados	Windows 4624 Logon Type 3, 5140/5145 (acesso a compartilhamentos), 7045 (serviço criado), firewall interno, EDR.
Perguntas de investigação	SMB saindo para a internet (quase nunca é legítimo)? Uma estação acessando ADMIN$/C$ de várias outras? Volume massivo de renomeação/escrita (ransomware)? Novo serviço criado logo após o acesso?

FTP — porta 21 (controle) / 20 ou portas dinâmicas (dados) • TCP

Aspecto	Descrição
Função	Transferência de arquivos antiga, **sem cifra**: usuário, senha e arquivos em texto claro.
Como aparece em ataques	Captura de credenciais; exfiltração; servidores FTP expostos com login anônimo.
Logs relacionados	Logs do servidor FTP, firewall, Zeek ftp.log.
Perguntas de investigação	Por que FTP ainda existe aqui? Quem enviou o quê? Credenciais trafegando em claro pela internet?

SFTP — porta 22 • TCP (sobre SSH)

Aspecto	Descrição
Função	Transferência de arquivos sobre SSH, cifrada. Não confundir com FTPS (FTP sobre TLS, portas 990/21).
Como aparece em ataques	Exfiltração cifrada para servidores externos; mesmo vetor de autenticação do SSH.
Logs relacionados	Logs SSH/SFTP do servidor, firewall (volume), DLP.
Perguntas de investigação	Destino é parceiro autorizado? Volume compatível com a rotina? Horário?

Identidade (aprofundado no Módulo 8)

LDAP — porta 389 • TCP (e UDP)

Aspecto	Descrição
Função	Consulta e alteração do diretório (Active Directory): usuários, grupos, computadores, atributos.
Como aparece em ataques	Enumeração do AD com ferramentas de reconhecimento (ex.: coleta massiva de usuários, grupos e relações); binds em texto claro expondo credenciais.
Logs relacionados	Logs do controlador de domínio (eventos de consulta LDAP quando auditados), EDR, firewall, soluções de identidade (ex.: Defender for Identity).
Perguntas de investigação	Quem consultou volumes anormais do diretório? A origem é servidor de aplicação conhecido ou uma estação? Bind simples (senha em claro)?

LDAPS — porta 636 (e 3269 para Global Catalog SSL) • TCP

Aspecto	Descrição
Função	LDAP sobre TLS.
Como aparece em ataques	Mesma enumeração, agora cifrada (menos visível na rede, mais dependente de logs do DC e EDR).
Logs relacionados	Logs do DC, EDR, plataformas de identidade.
Perguntas de investigação	Mesmas perguntas do LDAP; visibilidade passa a depender do endpoint e do DC.

Kerberos — porta 88 • TCP e UDP

Aspecto	Descrição
Função	Protocolo de autenticação padrão do Active Directory: tickets (TGT e TGS) emitidos pelo controlador de domínio (KDC).
Como aparece em ataques	Kerberoasting, AS-REP Roasting, Golden/Silver Ticket, password spraying via pré-autenticação.
Logs relacionados	Windows 4768 (TGT), 4769 (ticket de serviço), 4771 (falha de pré-autenticação) nos DCs.
Perguntas de investigação	Muitos 4769 com cifra RC4 (0x17) pedidos por um usuário? 4771 em massa para muitas contas? Tickets fora do padrão de horário/origem?

NTLM — porta sem porta própria (dentro de SMB, HTTP, RPC...) • —

Aspecto	Descrição
Função	Protocolo de autenticação legado do Windows por desafio-resposta. Ainda usado quando Kerberos não é possível (acesso por IP, sistemas antigos).
Como aparece em ataques	Pass-the-hash, NTLM relay, brute force e spraying, captura de hashes por envenenamento LLMNR/NBT-NS.
Logs relacionados	Windows 4776 (validação de credencial no DC), 4624 com "Authentication Package: NTLM", 4625.
Perguntas de investigação	Por que NTLM e não Kerberos? Origem é uma estação autenticando em muitas outras? Falhas em massa no 4776?

Resumo dos protocolos

Protocolo	Porta	Transp.	Abuso típico	Evidência principal
HTTP	80	TCP	Credencial em claro, download, exploração web	Proxy, WAF, web server
HTTPS	443	TCP/UDP	C2 e exfiltração cifrados	Proxy TLS, SNI, EDR
DNS	53	UDP/TCP	DGA, tunneling	Resolver, Sysmon 22
DHCP	67/68	UDP	Rogue DHCP	Servidor DHCP
SMTP	25/587	TCP	Phishing, spam de estação	Gateway de e-mail
IMAP/POP3	143/993, 110/995	TCP	Spraying sem MFA	Logs do IdP/e-mail

Protocolo	Porta	Transp.	Abuso típico	Evidência principal
SSH	22	TCP	Brute force, túneis	auth.log / secure
RDP	3389	TCP	Ransomware via exposição	4624/4625 tipo 10
SMB	445	TCP	Movimento lateral, ransomware	4624 tipo 3, 5140, 7045
LDAP/LDAPS	389/636	TCP	Enumeração do AD	DC, EDR
Kerberos	88	TCP/UDP	Kerberoasting, AS-REP	4768, 4769, 4771
NTLM	—	—	Pass-the-hash, relay	4776, 4624
FTP	21	TCP	Credenciais em claro	Servidor FTP, Zeek
SFTP	22	TCP	Exfiltração cifrada	Servidor, firewall
SNMP	161/162	UDP	Community padrão	Equipamento, firewall
NTP	123	UDP	Amplificação, horário errado	Firewall, serviço de tempo
ICMP	—	—	Ping sweep, tunneling	Firewall, IDS

MOMENTO SOC

Firewall da empresa, regra 1: "ANY → ANY → 3389 → ALLOW (temporário, liberado para o fornecedor, 2021)".

Fornecedor: não presta mais serviço desde 2022.

Regra: continua lá, firme, como um monumento.

Quando aparecer alerta de brute force em RDP vindo da internet, a pergunta certa não é só "quem está atacando", é "por que isso está exposto?". Essa pergunta vai para a recomendação do ticket.

1.15 Firewall

O **firewall** controla o tráfego entre redes ou zonas com base em regras: o que é permitido, o que é bloqueado e o que é registrado. Para o SOC, ele é ao mesmo tempo **controle** (pode bloquear) e **sensor** (registra quem falou com quem).

Conceito	O que é	Para o SOC
Stateless (filtro de pacotes)	Avalia cada pacote isoladamente (IP, porta, protocolo), sem memória de conexões.	Precisa de regras para ida e volta; comum em ACLs de roteador.
Stateful	Mantém tabela de sessões; respostas de conexões permitidas passam automaticamente.	Log por sessão (início/fim, bytes, duração) — o mais útil para investigação.
NGFW (Next-Generation)	Stateful + identificação de aplicação, usuário, inspeção TLS, IPS, filtro de URL, sandbox.	Logs ricos: app, usuário, categoria, ameaça. Mais contexto por evento.
ACL	Lista ordenada de regras permit/deny avaliadas de cima para baixo; a primeira que casa decide.	Ordem importa: uma regra ampla no topo anula as específicas abaixo.

Conceito	O que é	Para o SOC
Allow / Deny / Drop / Reject	Permitir; negar descartando em silêncio (drop) ou respondendo com RST/ICMP (reject).	Drop gera "filtrado" para quem varre; reject revela que há um firewall.
Inbound / Outbound	Entrando na zona protegida / saindo dela.	Inbound bloqueado é ruído de internet; **outbound** suspeito costuma ser mais grave (C2, exfiltração).
North-south	Tráfego entre a empresa e o exterior.	Onde estão firewall de borda, proxy, WAF.
East-west	Tráfego interno entre zonas/hosts.	Movimentação lateral vive aqui; muitas vezes com pouca visibilidade.
Implicit deny	Regra final invisível: tudo que não foi permitido é negado.	Logs de "deny implícito" mostram tentativas fora da política.

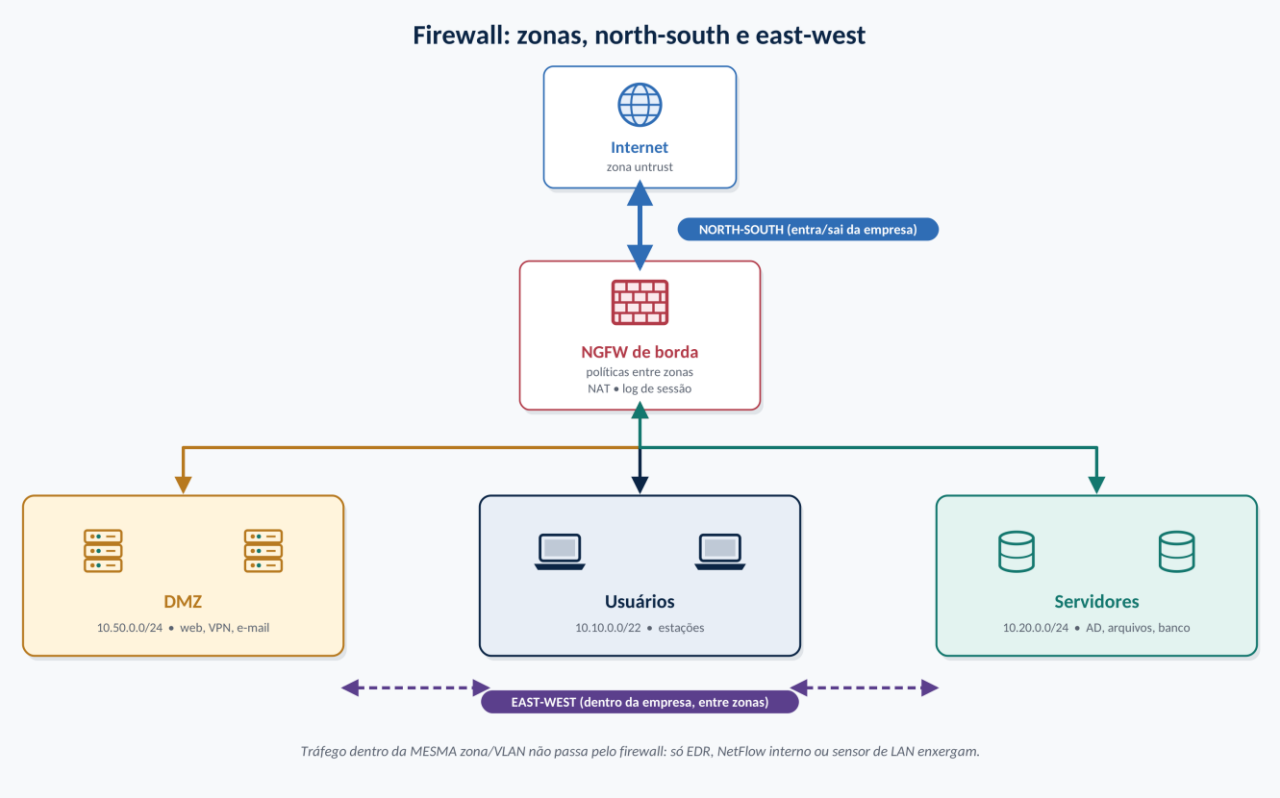


Figura 1.17 — Zonas de firewall, tráfego north-south e east-west

Lendo um log de firewall

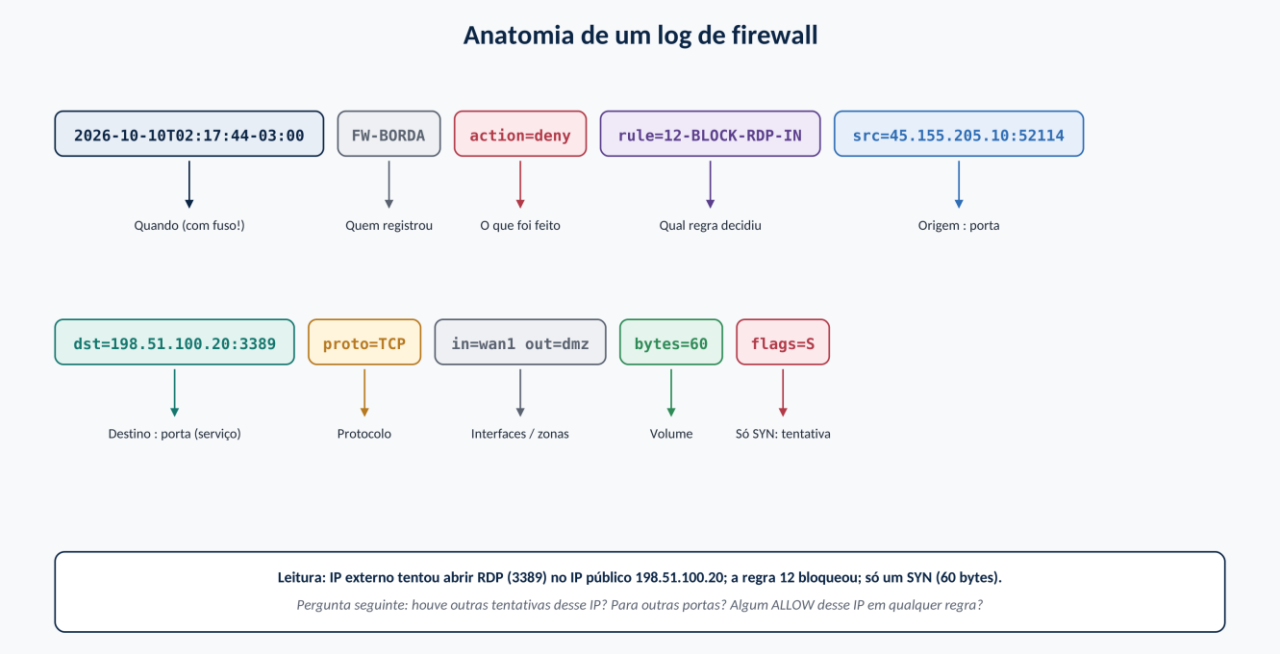


Figura 1.18 — Campos de um log de firewall e a leitura que o N1 deve fazer

Campo	Também aparece como	O que responde
source / src	srcip, src_ip, SourceIP, client	Quem iniciou a conexão (lado do primeiro SYN).
destination / dst	dstip, dest_ip, DestinationIP, server	Para onde ia.
src port	srcport, spt, s_port	Normalmente efêmera; essencial para casar com NAT.
dst port	dstport, dpt, service	Serviço pretendido.
action	act, disposition, verdict	Permitido, negado, descartado, resetado.
rule	policyid, rule_name, acl	Qual regra decidiu (e se é a regra que deveria).
interface / zona	srcintf/dstintf, from/to zone	Por onde entrou e saiu: direção e segmento.
bytes	sentbyte/rcvdbyte, bytes_in/out	Volume: tentativa (60 bytes) ou transferência real (MB/GB).
session	sessionid, duration, end_reason	Duração e motivo de encerramento (fin, rst, timeout, policy-deny).
app / user	appid, application, srcuser	Em NGFW: aplicação identificada e usuário (via integração com AD).

Exemplos de log

```
# FortiGate (estilo key=value)
date=2026-10-10 time=02:17:44 tz="-0300" devname="FW-BORDA" type="traffic" subtype="forward"
level="notice"
srcip=45.155.205.10 srcport=52114 srcintf="wan1" dstip=198.51.100.20 dstport=3389 dstintf="dmz"
policyid=12 policyname="BLOCK-RDP-IN" action="deny" proto=6 service="RDP" sentbyte=60 rcvdbyte=0

# Palo Alto (CSV, campos principais reordenados para leitura)
TRAFFIC,end,2026/10/10 09:41:03,src=10.10.0.87,dst=192.0.2.66,natsrc=198.51.100.7,rule=Allow-Web,
srcuser=corp\jsilva,app=ssl,from=trust,to=untrust,sport=52811,dport=443,natsport=40988,
```

```
action=allow,bytes=4831102,bytes_sent=4790011,bytes_received=41091,elapsed=1810,session_end_reason=tcp-fin

# iptables / nftables (Linux) com LOG
Oct 10 02:31:07 srv-web01 kernel: [FW-DROP] IN=eth0 OUT= SRC=203.0.113.77 DST=10.50.0.20 LEN=60 TTL=49 PROTO=TCP SPT=40122 DPT=22 WINDOW=64240 SYN

# Windows Firewall (pfirewall.log)
2026-10-10 02:33:12 DROP TCP 10.10.0.66 10.10.0.87 41001 445 52 S - - - - - - - - RECEIVE
```

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Repare no segundo log (Palo Alto): permitido, regra "Allow-Web", app ssl. Parece navegação. Mas: **4,79 MB enviados e 41 KB recebidos**, 30 minutos, para um IP sem nome conhecido.
>
> Navegação normal **baixa** mais do que envia. Upload grande para destino desconhecido merece uma olhada. `action=allow` não é sinônimo de "está tudo bem"; significa apenas "a regra deixou passar".

Perguntas padrão diante de um log de firewall

1. Quem iniciou? (src) É interno ou externo? Que ativo é?
2. Para onde e qual serviço? (dst, dst port, app)
3. Foi permitido ou bloqueado? Por qual regra? Essa regra faz sentido?
4. Completou? Quanto trafegou e em que direção? Quanto durou?
5. É recorrente? Mesmo src contra outros destinos/portas? Outros srcs contra o mesmo destino?
6. Há NAT envolvido? Qual era o IP/porta real?
7. O que os outros sensores dizem (EDR, proxy, DNS) no mesmo horário?

Leitura de SOC	
O que procuro	Allows inesperados (especialmente outbound para destinos raros e inbound para serviços sensíveis), volume e direção dos bytes, regras amplas, padrões repetitivos.
Pode ser benigno	Deny de ruído da internet contra a borda (varreduras automáticas constantes), backups e sincronizações com volume alto para destinos conhecidos, atualizações de software.
Pode ser suspeito	Allow inbound para RDP/SMB/SSH a partir da internet; upload grande para IP/ASN desconhecido; conexões outbound periódicas (a cada X segundos) para o mesmo destino; estação falando com a internet em portas não web.
Próximo passo	Enriquecer o IP/domínio externo, identificar o host interno e o processo (EDR), verificar NAT, buscar recorrência histórica, confirmar se a regra é a esperada.
Quando escalo	Comunicação bem-sucedida com IOC conhecido; exposição de serviço crítico à internet com tentativas ativas; indício de exfiltração ou beaconing.

> **NA VIDA REAL**
>
> Fila de alertas: 4.000 eventos de "deny inbound" na borda.
>
> Analista novo: "Estamos sob ataque!"

> Analista experiente: "Estamos na internet."
>
> A borda de qualquer empresa recebe varreduras o dia inteiro. O deny está fazendo o trabalho dele. O que tira o sono é o **allow** que não deveria estar lá.

1.16 Proxy

Um **proxy** é um intermediário: o cliente fala com o proxy, e o proxy fala com o destino em nome dele. Isso permite controlar, filtrar, registrar e, em alguns casos, inspecionar o tráfego.

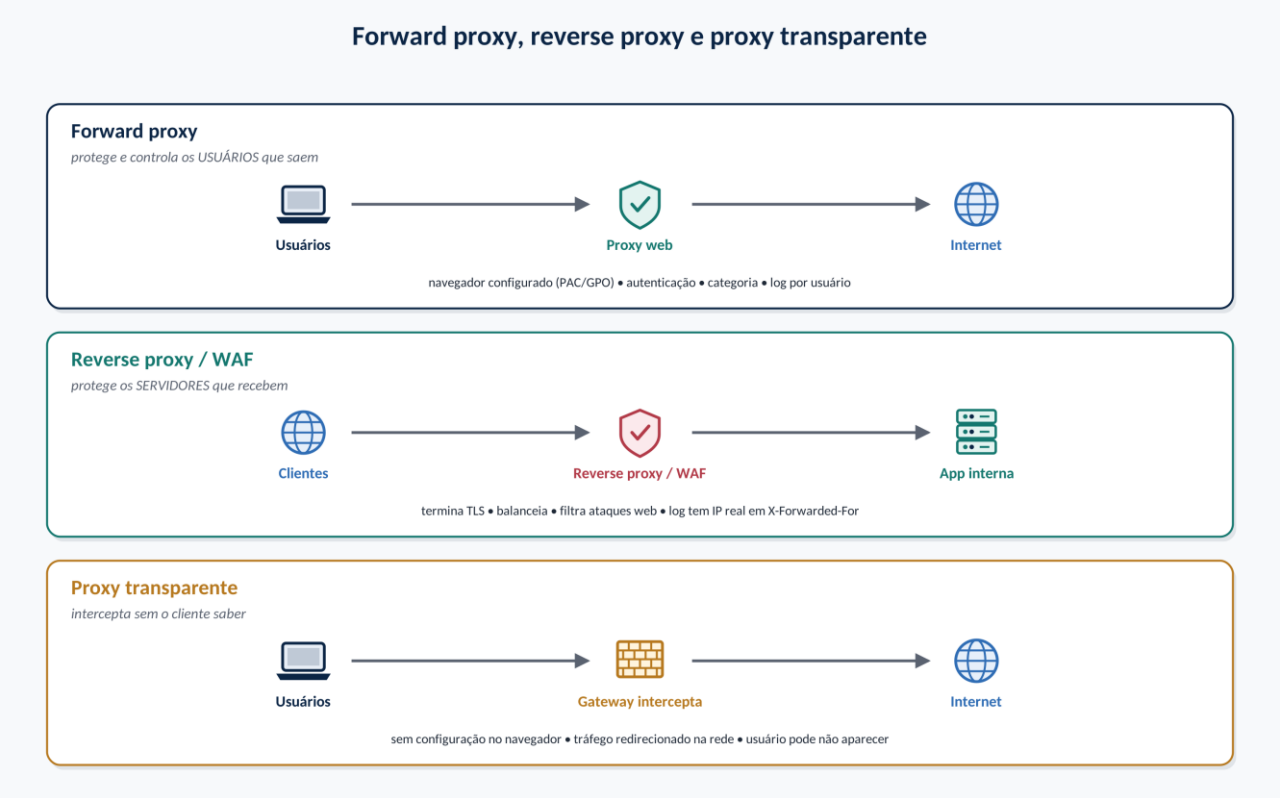


Figura 1.19 — Os três tipos de proxy e o que cada um registra

Tipo	Protege	Como funciona	Valor para o SOC
Forward proxy	Os usuários que saem para a internet.	O navegador é configurado (PAC, GPO, agente) para enviar as requisições ao proxy.	Log com **usuário**, URL, categoria, veredito, user-agent. Uma das melhores fontes de investigação de navegação.
Reverse proxy	Os servidores que recebem acessos.	Fica na frente da aplicação, recebe as conexões dos clientes e repassa aos servidores internos (frequentemente com WAF e balanceamento).	Log com IP real do cliente, URL, código de resposta; servidor interno vê o IP do proxy (o IP real vai no cabeçalho `X-Forwarded-For`).
Transparent proxy	Usuários, sem configuração no cliente.	A rede redireciona o tráfego web para o proxy sem o cliente saber.	Vê tráfego mesmo de dispositivos não configurados; identificação de usuário pode ser mais fraca.

Logs típicos

```
# Squid (access.log, formato nativo)
1791626543.112   1840 10.10.0.87 TCP_MISS/200 52311 GET http://downloads.exemplo-
cdn.example/setup.exe jsilva HIER_DIRECT/203.0.113.44 application/octet-stream

# Proxy em nuvem / SWG (campos típicos, formato genérico)
time=2026-10-10T10:02:11-03:00 user=jsilva@empresa.example src=10.10.0.87 action=blocked
url=https://atualizacao-cadastro-banco.example/login category="Newly Registered Domains"
threat="Phishing"
method=GET status=403 useragent="Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/129.0"
bytes_out=812 bytes_in=0

# Proxy: user-agent incomum em estação Windows
time=2026-10-10T10:05:40-03:00 user=jsilva src=10.10.0.87 action=allowed
url=http://192.0.2.66/a.ps1
method=GET status=200 useragent="Mozilla/5.0 (Windows NT; Windows NT 10.0; pt-BR)
WindowsPowerShell/5.1" content_type=text/plain

# Reverse proxy / servidor web atrás dele (IIS com X-Forwarded-For)
2026-10-10 13:02:11 10.50.0.5 GET /portal/login.aspx - 443 - 10.50.0.2 Mozilla/5.0 - 200 0 0
112  XFF=203.0.113.150
```

Campo	Por que importa
Usuário	Liga a navegação a uma pessoa sem depender de DHCP/NAT.
URL completa	Caminho, parâmetros, extensão (.exe, .ps1, .hta, .zip).
Categoria / reputação	Domínio recém-registrado, phishing, malware, sem categoria.
Ação / status HTTP	Bloqueado pelo proxy (403 do proxy) é diferente de erro do site.
User-agent	`WindowsPowerShell`, `curl`, `python-requests`, `certutil`, `BITS` em estação de usuário merecem olhar.
Content-type e bytes	Download de binário; upload grande (bytes_out alto).
X-Forwarded-For	Em reverse proxy/CDN, o IP real do cliente.

MOMENTO SOC

Usuário: "Eu não baixei nada."

Proxy: `GET /fatura_outubro.zip` às 10:01:58, usuário jsilva, status 200.

Proxy: `GET /fatura_outubro.exe`... não, espera. Esse foi o `wscript.exe` às 10:02:31, com user-agent estranho.

O usuário provavelmente está falando a verdade sobre o segundo download. Ele clicou no primeiro. O malware fez o resto. Isso não é para culpar ninguém: é para montar a timeline correta.

Leitura de SOC	
O que procuro	URLs e categorias de risco, downloads de executáveis/scripts, user-agents não-navegador, uploads grandes, bloqueios repetidos (indicam tentativa persistente, às vezes automatizada).
Pode ser benigno	Atualizadores de software (com user-agents próprios), ferramentas de TI conhecidas, bloqueios por categoria de entretenimento, downloads de instaladores de sites oficiais.

Leitura de SOC	
Pode ser suspeito	Script baixado por user-agent PowerShell/certutil; acesso a domínio recém-registrado após clique em e-mail; requisições periódicas para o mesmo destino sem categoria; upload massivo para serviço de armazenamento pessoal.
Próximo passo	Montar timeline (e-mail → clique → download → execução), verificar no EDR o processo que fez a requisição e o que aconteceu com o arquivo, buscar outros usuários que acessaram o mesmo domínio.
Quando escalo	Download seguido de execução, comunicação com domínio malicioso confirmado após o download, vários usuários acessando o mesmo link malicioso.

1.17 VPN

Uma **VPN** (Virtual Private Network) cria um **túnel cifrado** sobre uma rede não confiável (a internet), fazendo com que um dispositivo ou uma rede remota funcione como se estivesse dentro da rede corporativa. Para o atacante, uma credencial de VPN válida é a porta da frente: ele entra como funcionário.

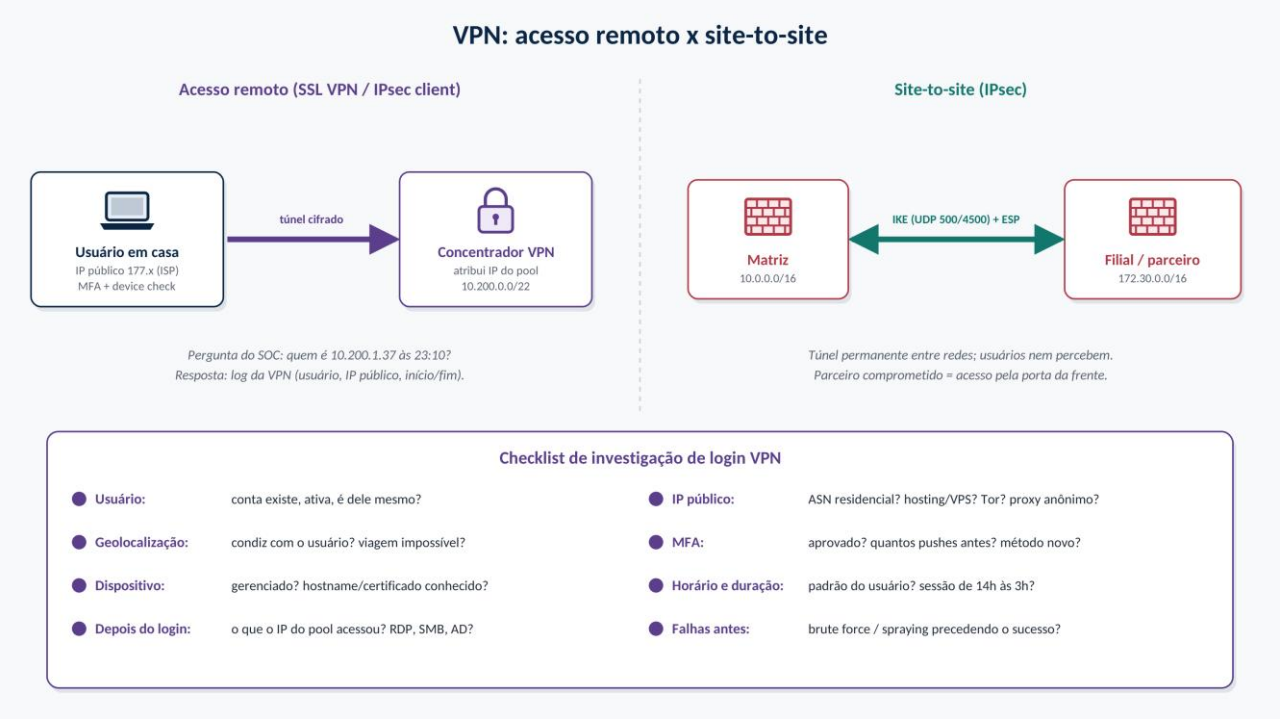


Figura 1.20 — VPN de acesso remoto e site-to-site, com o checklist de investigação de login

Tipo	Uso	Tecnologia	Logs
Remote access	Funcionário em casa ou viajando acessa a rede interna.	SSL VPN (TLS, geralmente 443) ou cliente IPsec/IKEv2.	Concentrador VPN: usuário, IP público, IP atribuído, MFA, duração, bytes.
Site-to-site	Ligar filiais, data centers, nuvem ou parceiros.	IPsec (IKE em UDP 500/4500, ESP).	Túnel up/down, negociação IKE, tráfego entre redes no firewall.
SSL VPN	Acesso remoto via TLS, às vezes pelo navegador (portal).	TLS sobre TCP 443 (às vezes DTLS/UDP).	Portal web + logs de autenticação. Alvo frequente de vulnerabilidades críticas em appliances.

Tipo	Uso	Tecnologia	Logs
IPsec	Site-to-site e alguns clientes.	IKE + ESP.	Fases de negociação, falhas de chave, túnel.

Investigando um login de VPN

```
# Concentrador VPN (formato genérico)
2026-10-10T03:12:40-03:00 vpn-gw01 event=auth_success user=mpereira src_ip=45.142.120.33
src_country=NL
  assigned_ip=10.200.1.37 mfa=push_approved mfa_attempts=7 client=AnyClient/5.1 os=Windows
device_managed=false
2026-10-10T03:12:41-03:00 vpn-gw01 event=tunnel_up user=mpereira assigned_ip=10.200.1.37
2026-10-10T05:47:02-03:00 vpn-gw01 event=tunnel_down user=mpereira duration=9261s
bytes_in=31208 bytes_out=2147483648

# Falhas que antecederam (mesmo IP)
2026-10-10T02:58:11-03:00 vpn-gw01 event=auth_failure user=mpereira src_ip=45.142.120.33
reason=bad_password
2026-10-10T03:01:02-03:00 vpn-gw01 event=auth_failure user=apaiva  src_ip=45.142.120.33
reason=bad_password
2026-10-10T03:01:05-03:00 vpn-gw01 event=auth_failure user=rcosta  src_ip=45.142.120.33
reason=bad_password
```

Elemento	O que observar neste exemplo	Avaliação
Horário	03:12 da manhã	Fora do padrão comum; confirmar com histórico do usuário.
IP público / país	45.142.120.33, Holanda	Usuário trabalha no Brasil? Consultar ASN (hosting/VPS é mais suspeito que operadora residencial).
Falhas antes	Falhas para mpereira, apaiva, rcosta do mesmo IP	Padrão de **password spraying** antes do sucesso.
MFA	push aprovado após **7 tentativas**	Indício clássico de **MFA fatigue**: o usuário aprovou para parar as notificações.
Dispositivo	não gerenciado	Não é o notebook corporativo.
Duração e volume	2h34, **2 GB enviados** da rede para fora	Possível exfiltração.
Depois do login	O que 10.200.1.37 acessou?	Buscar no firewall interno, AD (4624 de origem 10.200.1.37), EDR dos servidores.

🎯 O QUE UM N1 REALMENTE PRECISA SABER

Este caso **não é** para o N1 resolver sozinho. É para o N1 **reconhecer em minutos** e escalar com as evidências organizadas: spraying + sucesso + MFA fatigue + país incomum + dispositivo não gerenciado + volume de saída.

Contenção (derrubar sessão, desabilitar conta, resetar credenciais e MFA) acontece **conforme o Playbook e a autorização**, normalmente acionada pelo N2/IR. Veremos esses Playbooks nos Módulos 17 e 18.

Leitura de SOC	
O que procuro	Usuário, IP público (ASN, país, reputação, Tor/VPS), MFA (tentativas, método), dispositivo, horário, duração, bytes, falhas anteriores e atividade interna do IP atribuído.
Pode ser benigno	Usuário em viagem a trabalho (confirmada), mudança de operadora, VPN corporativa de celular, IP de saída de hotel/aeroporto, plantonista acessando de madrugada.
Pode ser suspeito	Login após spraying; MFA aprovado após muitas notificações; IP de hosting/VPS/Tor; dispositivo não gerenciado; dois logins simultâneos de países diferentes; volume de saída alto; acessos internos fora do perfil do usuário.
Próximo passo	Consultar histórico de logins do usuário, enriquecer o IP, verificar atividade do IP atribuído, contatar o usuário pelo canal definido (não pelo e-mail possivelmente comprometido).
Quando escalo	Qualquer combinação de login bem-sucedido com sinais fortes de comprometimento (spraying prévio, MFA fatigue, origem anônima, exfiltração). Esse é um caso de **conta comprometida até prova em contrário**.

1.18 Wireshark e tcpdump

O **Wireshark** é o analisador de pacotes gráfico mais usado do mundo. O **tcpdump** é a ferramenta de linha de comando para capturar (e ler) tráfego, presente em praticamente todo Linux. Um N1 raramente captura tráfego em produção, mas frequentemente recebe um **PCAP** (arquivo de captura) gerado por um sensor, IDS, sandbox ou pelo time de redes e precisa extrair informações dele.

> ⛔ **ATENÇÃO**
>
> Capture tráfego **apenas** em redes e equipamentos que são seus ou com autorização explícita e por escrito. Captura de tráfego de terceiros pode ser crime e, em empresa, viola política.
>
> PCAPs podem conter **senhas, cookies e dados pessoais**. Trate como evidência confidencial: não envie para serviços públicos, não deixe em pastas compartilhadas.

A tela do Wireshark em 30 segundos

- **Lista de pacotes** (topo): número, tempo, origem, destino, protocolo, tamanho e resumo.
- **Detalhes do pacote** (meio): o encapsulamento aberto camada por camada (Frame → Ethernet → IP → TCP → aplicação). É o modelo da Parte 1, ao vivo.
- **Bytes** (baixo): o conteúdo em hexadecimal e ASCII.
- **Barra de filtro**: onde você vai passar 80% do tempo.

Filtros de exibição essenciais

Filtro	Mostra	Uso típico
`ip.addr == 10.10.0.66`	Pacotes com esse IP como origem **ou** destino	Focar num host.
`ip.src == 10.10.0.66`	Só com esse IP como origem	O que o host enviou.
`ip.dst == 10.20.0.10`	Só com esse IP como destino	Quem falou com o servidor.

Filtro	Mostra	Uso típico
`tcp.port == 445`	TCP com porta 445 na origem ou no destino	Focar num serviço.
`tcp.dstport == 3389`	Conexões para RDP	Quem tentou RDP.
`dns`	Todo tráfego DNS	Quais domínios foram consultados.
`dns.flags.rcode == 3`	Respostas NXDOMAIN	Caçar DGA.
`dns.qry.type == 16`	Consultas TXT	Caçar tunneling.
`http`	Tráfego HTTP em claro	URLs, métodos, user-agents.
`http.request.method == "POST"`	Envios de formulário	Logins, uploads.
`tls`	Tráfego TLS	Handshakes e SNI.
`tls.handshake.extensions_server_name`	Pacotes com SNI	Nomes acessados em HTTPS.
`tcp.flags.syn == 1 && tcp.flags.ack == 0`	Só SYN iniciais	Tentativas de conexão; varreduras.
`tcp.flags.reset == 1`	Pacotes RST	Recusas e abortos.
`icmp.type == 8`	Echo Request	Ping sweep.
`arp`	ARP	ARP spoofing.
`dhcp` (em versões antigas: `bootp`)	DHCP	IP ↔ MAC ↔ hostname.
`!(arp or dns)`	Tudo exceto ARP e DNS	Reduzir ruído.
`frame.time >= "2026-10-10 02:00:05"`	A partir de um horário	Recortar a janela do alerta.

> **DICA**
>
> **Filtro de exibição** (display filter, sintaxe acima) apenas esconde pacotes já capturados. **Filtro de captura** (capture filter, sintaxe BPF, a mesma do tcpdump: `host 10.10.0.66 and port 445`) decide o que entra no arquivo. São linguagens diferentes, e misturá-las é o erro número 1 de quem começa.
>
> Atalhos que valem ouro: **Statistics → Conversations**, **Statistics → Protocol Hierarchy**, **Statistics → Endpoints**, botão direito **Follow → TCP Stream / HTTP Stream**, **File → Export Objects → HTTP**.

Método de análise

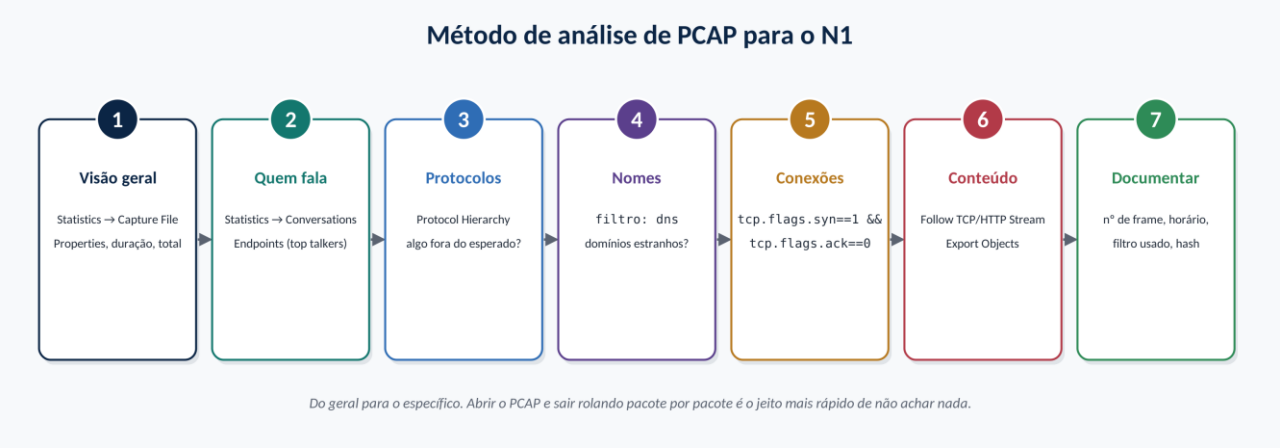


Figura 1.21 — Do geral para o específico: sete passos para analisar um PCAP

tcpdump

```
sudo tcpdump -D                                  # listar interfaces
sudo tcpdump -i eth0 -nn                         # capturar sem resolver nomes/portas
sudo tcpdump -i eth0 -nn host 10.10.0.66         # só um host
sudo tcpdump -i eth0 -nn port 53                 # só DNS
sudo tcpdump -i eth0 -nn 'tcp[tcpflags] & tcp-syn != 0 and tcp[tcpflags] & tcp-ack == 0'   #
só SYN
sudo tcpdump -i eth0 -nn -w captura.pcap         # gravar em arquivo
sudo tcpdump -i eth0 -nn -c 500 -w amostra.pcap  # parar após 500 pacotes
tcpdump -nn -r captura.pcap                      # ler arquivo (não precisa de root)
tcpdump -nn -r captura.pcap 'icmp' | wc -l       # contar pacotes ICMP
tcpdump -nn -A -r captura.pcap 'tcp port 80'     # mostrar conteúdo ASCII (HTTP em claro)
sha256sum captura.pcap                           # registrar o hash da evidência
```

Uma linha típica de saída do tcpdump:

```
02:00:04.120391 IP 10.10.0.66.41877 > 10.20.0.10.23: Flags [S], seq 7777, win 8192, length 0
02:00:04.121420 IP 10.20.0.10.23 > 10.10.0.66.41877: Flags [R.], seq 0, ack 7778, win 0,
length 0
#  [S]=SYN  [S.]=SYN-ACK  [.]=ACK  [P.]=PSH-ACK  [F.]=FIN-ACK  [R]=RST  [R.]=RST-ACK
```

Desafios com PCAP

O arquivo **Lab_Modulo01_desafios.pcap** está **anexado dentro deste documento**, logo abaixo. No Word para Windows, clique duas vezes no ícone e abra com o Wireshark (ou clique com o botão direito → Objeto Pacote → Abrir). Se preferir, salve o anexo numa pasta do seu laboratório antes de abrir.



Anexo: Lab_Modulo01_desafios.pcap (28 KB). Em Word para Mac, Word Online ou LibreOffice o ícone pode não abrir; nesse caso use a cópia do arquivo entregue separadamente.

Abra a captura no Wireshark. É uma captura **sintética** de cerca de 18 segundos em uma rede corporativa fictícia, iniciada em 10/10/2026 às 02:00 UTC. Todos os IPs são privados ou reservados para documentação. Responda **antes** de consultar as respostas no fim do módulo.

#	Desafio	Dica de filtro / recurso
P1	Quantos pacotes há na captura e qual o horário do primeiro pacote em UTC e em horário de Brasília?	Statistics → Capture File Properties; View → Time Display Format.
P2	Qual hostname e qual MAC receberam o IP 10.10.0.87? Que gateway e DNS o servidor entregou?	`dhcp`
P3	O host 10.10.0.87 acessou qual nome e qual IP? A conexão completou o handshake? Qual porta de origem?	`dns`, depois `ip.addr == 203.0.113.80`
P4	Um host enviou credenciais em texto claro. Qual host, para qual servidor, qual usuário e qual senha? O login funcionou?	`http.request.method == "POST"` + Follow HTTP Stream
P5	Qual host fez descoberta por ICMP? Quantos destinos testou e quantos responderam? Quais?	`icmp.type == 8`, `icmp.type == 0`
P6	O mesmo host varreu portas TCP de qual servidor? Quantos SYN enviou? Quais portas estavam abertas?	`tcp.flags.syn == 1 && tcp.flags.ack == 0`, depois `tcp.flags.syn == 1 && tcp.flags.ack == 1`
P7	Há sinais de ARP spoofing? Qual MAC anunciou ser o gateway 10.10.0.1? Qual o fabricante provável (OUI)? Qual o MAC legítimo?	`arp`
P8	Qual host gerou muitas respostas NXDOMAIN? Quantas? Algum dos domínios resolveu? Houve conexão ao IP retornado?	`dns.flags.rcode == 3`, `dns.flags.rcode == 0 && ip.dst == 10.10.0.91`
P9	Qual host faz consultas TXT com subdomínios longos? Para qual domínio? Quantas consultas? Que informação parece estar saindo?	`dns.qry.type == 16`; decodificar o subdomínio (Base32).
P10	Monte uma timeline curta (horário UTC, host, evento) dos achados e diga quais você escalaria e por quê.	Junte as respostas anteriores.

LABORATÓRIO — Lab 1.4 — Investigando o PCAP com tcpdump

Repita P5, P6 e P8 **somente com tcpdump** (em Linux, WSL ou na VM Ubuntu):

- `tcpdump -nn -r Lab_Modulo01_desafios.pcap 'icmp[icmptype] == 8' | wc -l`
- `tcpdump -nn -r Lab_Modulo01_desafios.pcap 'src host 10.20.0.10 and tcp[tcpflags] & (tcp-syn|tcp-ack) == (tcp-syn|tcp-ack)'`
- `tcpdump -nn -r Lab_Modulo01_desafios.pcap 'udp port 53' | grep -c NXDomain`
- Registre o SHA-256 do arquivo antes de começar e cole no seu relatório.

Documente em `labs/lab-1.4.md`, com os comandos usados e a saída relevante.

Fechamento do Módulo 1

Ferramentas do módulo

Ferramenta	Para que serve no SOC	Gratuita?
`netstat` / `ss` / `Get-NetTCPConnection`	Conexões, estados e processos num host.	Nativo
`Test-NetConnection` / `nc`	Testar se uma porta responde (no seu ambiente).	Nativo / pacote
`ping` / `tracert` / `traceroute` / `mtr`	Alcançabilidade e caminho.	Nativo
`nslookup` / `dig` / `whois`	DNS e registro de domínios.	Nativo / pacote
Wireshark	Análise gráfica de PCAP.	Sim
tcpdump	Captura e leitura de PCAP em linha de comando.	Sim
Zeek	Transforma tráfego em logs (conn, dns, http, ssl, dhcp).	Sim
Suricata	IDS/IPS com assinaturas.	Sim
Consoles de firewall, proxy e VPN	Onde vivem os logs de borda (cada fabricante tem o seu).	Comercial

Erros comuns

Erro	Por que é um problema	Como evitar
Ler o pacote de resposta e achar que o servidor iniciou	Inverte a história do incidente.	Procurar o primeiro SYN, o campo originador ou `Initiated`.
Tratar porta efêmera como serviço	"Conexão na porta 51523" não significa nada.	Serviço = porta do lado que estava em LISTEN.
Achar que `allow` = benigno	O malware passa por regras permitidas.	Avaliar destino, volume, direção, processo.
Achar que `deny` = ataque grave	Borda bloqueia ruído o dia todo.	Priorizar allows inesperados e sinais internos.
Confiar na porta para identificar aplicação	Qualquer coisa roda em 443.	App-id do NGFW, SNI, processo no EDR.
Esquecer o UDP	DNS tunneling e reflexão passam despercebidos.	Incluir UDP nas consultas e políticas de egress.
Concluir sobre VPN só pelo "login bem-sucedido"	Credencial válida é exatamente o que o atacante usa.	MFA, IP, dispositivo, falhas anteriores, atividade posterior.
Misturar filtro de captura com filtro de exibição	O Wireshark não aceita e você perde tempo.	BPF para capturar; display filter para analisar.
Abrir PCAP e rolar sem método	Horas sem conclusão.	Estatísticas → conversas → protocolos → filtros.

Falsos positivos comuns

Alerta	Causa benigna frequente	Como confirmar
"Port scan interno"	Scanner de vulnerabilidades, inventário, monitoramento.	Origem na lista de scanners autorizados; janela aprovada.
"Ping sweep"	Ferramenta de monitoramento/descoberta de ativos.	Periodicidade regular, origem conhecida.
"Conexão para porta incomum"	Aplicação de negócio em porta alta; atualização de fornecedor.	Processo assinado e esperado; destino do fornecedor.
"Upload grande"	Backup em nuvem, sincronização de OneDrive/Drive, envio de vídeo para SaaS aprovado.	Destino e processo conhecidos; compatível com a rotina.
"Login VPN de país incomum"	Viagem a trabalho, roaming, GeoIP errado.	Confirmação com gestor/RH, ASN de operadora, histórico.
"Beaconing"	Agentes de monitoramento, telemetria, verificações de licença, NTP.	Destino de fornecedor conhecido, processo legítimo.
"DNS para resolver externo"	Equipamento de rede ou VM de laboratório com DNS fixo.	Ativo conhecido e documentado; não é estação de usuário.

Exercícios da Parte 2

1. Analise: `Pacote 1: 192.168.5.20:49833 → 10.30.0.15:1433 [SYN]`, `Pacote 2: 10.30.0.15:1433 → 192.168.5.20:49833 [SYN, ACK]`. Quem iniciou? Qual serviço provável? A conexão completou?
2. Um log mostra `src=10.20.0.10:445 dst=10.10.0.66:52110`. Um colega diz que "o servidor conectou na estação pela porta 52110". Ele está certo? Explique.
3. Explique a diferença entre os `conn_state` do Zeek `SF`, `REJ` e `S0` e o que cada um indica numa varredura.
4. Por que é mais difícil afirmar que uma "conexão" UDP teve sucesso do que uma TCP?
5. Você recebe um ping de resposta com TTL=63. O que isso sugere sobre o sistema e a distância?
6. Cite o protocolo, a porta e o Event ID principal para investigar: (a) brute force em área de trabalho remota do Windows; (b) movimentação lateral por compartilhamento administrativo; (c) Kerberoasting.
7. Um log de firewall mostra `action=allow app=ssl dst=203.0.113.99:443 bytes_sent=3.2GB bytes_received=20MB duration=2h` a partir de uma estação. O que chama atenção e quais seus próximos passos?
8. Qual a diferença entre forward proxy e reverse proxy? Em qual deles o campo `X-Forwarded-For` costuma ser essencial?
9. Um proxy registra user-agent `Microsoft-CryptoAPI/10.0` e `certutil` baixando `http://192.0.2.66/x.txt`. Por que isso é suspeito?
10. Liste sete elementos que você verificaria num login de VPN bem-sucedido às 3h da manhã.
11. Escreva o filtro de exibição do Wireshark para: (a) todo tráfego do host 10.10.0.45; (b) apenas SYN iniciais; (c) respostas DNS NXDOMAIN; (d) requisições POST.
12. Escreva o comando tcpdump que lê `caso.pcap` mostrando apenas tráfego DNS sem resolver nomes.

Laboratório integrado do Módulo 1

> **LABORATÓRIO — Lab 1.5 — Gerando e observando seu próprio tráfego**
>
> **Objetivo:** ver na prática DHCP, ARP, DNS, TCP, TLS, ICMP e UDP gerados por você. Use apenas sua máquina e sua rede.
>
> **Duração:** 60 a 90 minutos.
>
> - Abra o Wireshark e comece a capturar na interface principal.
> - No terminal: `ipconfig /release` e `ipconfig /renew` (Windows) ou reconecte a rede. Pare e filtre `dhcp`: identifique as 4 mensagens DORA.
> - Limpe o cache ARP (`arp -d *` como admin no Windows, ou `ip neigh flush all` no Linux) e faça `ping` no gateway. Filtre `arp`.
> - Rode `nslookup exemplo.com` e `ping exemplo.com`. Filtre `dns` e `icmp`. Anote o TTL da resposta do ping.
> - Abra um site em HTTPS. Filtre `tls.handshake.type == 1` e encontre o SNI.
> - Rode `tracert -d 8.8.8.8` e filtre `icmp.type == 11`. Conte os roteadores que responderam.
> - Rode `netstat -ano` durante a navegação e relacione uma conexão ESTABLISHED com o processo (PID).
> - Salve o PCAP, calcule o SHA-256 e escreva em `labs/lab-1.5.md` uma timeline com 10 eventos (horário, protocolo, origem, destino, o que significa).

> **LABORATÓRIO — Lab 1.6 — Leitura de logs sem ferramenta**
>
> Use os logs sintéticos de firewall, proxy e VPN deste volume (seções 1.15 a 1.17) e responda, para cada um, as 7 perguntas padrão do firewall (seção 1.15). Escreva um mini-ticket para o caso da VPN de `mpereira` com: resumo, evidências, análise, classificação provável e motivo de escalonamento.

Perguntas de entrevista — Parte 2

P: Qual a diferença entre TCP e UDP?

Resposta fraca	Resposta boa
"TCP é seguro e UDP não."	TCP é orientado a conexão: faz handshake, confirma, retransmite e garante ordem; é usado em HTTP, SSH, RDP, SMB. UDP não tem conexão nem garantia de entrega; é leve e usado em DNS, DHCP, NTP, VoIP. Nenhum dos dois é "seguro" por si: segurança vem de TLS, IPsec etc. No SOC, UDP exige atenção porque é forjável e usado para tunelamento e amplificação.

O que está sendo avaliado: Precisão conceitual e não confundir confiabilidade com segurança.

P: Explique o three-way handshake.

Resposta fraca	Resposta boa
"É quando o computador conecta no servidor."	O cliente envia SYN com seu número de sequência inicial; o servidor responde SYN-ACK com o seu e confirma o do cliente; o cliente responde ACK. A conexão fica ESTABLISHED. Quem envia o primeiro SYN

Resposta fraca	Resposta boa
	é quem iniciou. SYN sem resposta ou respondido com RST indica porta filtrada ou fechada, o que ajuda a identificar varreduras.

O que está sendo avaliado: Entendimento do mecanismo e aplicação investigativa.

P: Como você identifica quem iniciou uma conexão num log?

Resposta fraca	Resposta boa
"Pelo IP de origem."	O src do log de sessão do firewall, o originador no Zeek ou o campo Initiated no Sysmon 3. Se só tenho pacotes, procuro o primeiro SYN. Como heurística, o lado com porta alta efêmera costuma ser o cliente e o lado com porta conhecida, o servidor, mas confirmo, porque há serviços em portas altas.

O que está sendo avaliado: Raciocínio, conhecimento de fontes e cautela com heurísticas.

P: O que é uma porta efêmera?

Resposta fraca	Resposta boa
"Uma porta temporária."	É a porta de origem escolhida aleatoriamente pelo sistema do cliente para uma conexão, em faixa alta (49152–65535 no Windows). Ela não identifica serviço; serve para o sistema saber a que conexão pertence a resposta. É essencial para casar um log de NAT.

O que está sendo avaliado: Base para interpretar logs corretamente.

P: Quais portas você precisa conhecer e por quê?

Resposta fraca	Resposta boa
"80, 443, 22, 3389..."	As mais comuns em investigação: 80/443 web, 53 DNS, 22 SSH, 3389 RDP, 445 SMB, 88 Kerberos, 389/636 LDAP, 25/587 SMTP, 135 RPC, 5985 WinRM. Mais importante que a porta é saber o abuso típico e a evidência: RDP exposto e Logon Type 10, SMB e movimentação lateral com 4624 tipo 3 e 7045. E lembrar que a porta indica o serviço esperado, não garante o tráfego.

O que está sendo avaliado: Memória útil associada a raciocínio.

P: Qual a diferença entre firewall stateless, stateful e NGFW?

Resposta fraca	Resposta boa
"NGFW é o mais moderno."	Stateless avalia cada pacote isoladamente. Stateful mantém tabela de sessões e permite respostas de conexões conhecidas, gerando log por sessão. NGFW soma identificação de aplicação e usuário, inspeção TLS, IPS e filtro de URL, o que dá muito mais contexto ao log.

O que está sendo avaliado: Compreensão do que cada um enxerga.

P: O que você olha num log de firewall?

Resposta fraca	Resposta boa
"Se foi bloqueado."	Origem e destino, portas, ação e regra, interface/zona, bytes em cada direção, duração, NAT, aplicação e usuário se for NGFW. Depois: é recorrente? Há outros destinos? O que EDR, proxy e DNS dizem no mesmo horário? E lembro que allow inesperado costuma ser mais grave que deny.

O que está sendo avaliado: Método de análise.

P: Qual a diferença entre forward e reverse proxy?

Resposta fraca	Resposta boa
"Um é para frente e outro para trás."	Forward proxy fica na saída e protege/controla os usuários que acessam a internet; registra usuário, URL, categoria e user-agent. Reverse proxy fica na frente dos servidores e recebe acessos externos, frequentemente com WAF e balanceamento; o servidor interno vê o IP do proxy e o IP real do cliente vem em X-Forwarded-For.

O que está sendo avaliado: Arquitetura e implicação nos logs.

P: Como você investigaria um login de VPN suspeito?

Resposta fraca	Resposta boa
"Veria se a senha estava certa."	Verifico usuário, IP público com ASN e reputação, geolocalização e viagem impossível, MFA e número de tentativas, dispositivo gerenciado, horário e duração, falhas anteriores do mesmo IP contra outras contas e o que o IP atribuído acessou internamente. Contato o usuário por canal alternativo. Se houver spraying prévio ou MFA fatigue, trato como conta comprometida e escalo.

O que está sendo avaliado: Pensamento investigativo além da autenticação.

P: Que filtros de Wireshark você usa?

Resposta fraca	Resposta boa
"Eu filtro pelo IP."	ip.addr, ip.src, ip.dst e tcp.port para focar; dns, http e tls por protocolo; tcp.flags.syn==1 && tcp.flags.ack==0 para tentativas de conexão; dns.flags.rcode==3 para NXDOMAIN. Antes de filtrar, uso Statistics → Conversations e Protocol Hierarchy para ter visão geral, e Follow Stream para ver o conteúdo.

O que está sendo avaliado: Familiaridade prática e método.

Checklist de domínio do Módulo 1

Parte 1 (reveja o checklist do volume anterior) e **Parte 2**:

- ☐ Explico campos e flags do TCP e o three-way handshake.
- ☐ Digo quem iniciou uma conexão a partir de pacotes, log de firewall, Zeek ou Sysmon.
- ☐ Diferencio porta de serviço e porta efêmera.

- ☐ Interpreto estados TCP (LISTEN, ESTABLISHED, SYN_SENT, TIME_WAIT) e conn_state do Zeek.
- ☐ Reconheço varredura vertical e horizontal e as respostas aberta/fechada/filtrada.
- ☐ Explico UDP, por que é forjável e como aparece em tunelamento e amplificação.
- ☐ Explico ICMP, TTL, ping e traceroute e reconheço ping sweep.
- ☐ Para os 19 protocolos da seção 1.14, sei porta, transporte, função, abuso, log e pergunta.
- ☐ Diferencio stateless, stateful e NGFW, inbound/outbound e north-south/east-west.
- ☐ Leio um log de firewall campo a campo e faço as 7 perguntas padrão.
- ☐ Diferencio forward, reverse e transparent proxy e sei os campos úteis do log.
- ☐ Investigo um login de VPN com o checklist de 8 itens.
- ☐ Uso filtros essenciais do Wireshark e comandos básicos do tcpdump.
- ☐ Resolvi os 10 desafios do PCAP e os Labs 1.4, 1.5 e 1.6.

Resumo do Módulo 1

- **OSI** é o mapa para raciocinar; **TCP/IP** é a estrada real. Cada camada tem dispositivos, ataques e logs próprios.
- Um simples acesso HTTPS envolve **DNS, rota, ARP, TCP, NAT, TLS e HTTP**, cada um registrado em uma fonte diferente.
- **IP não é pessoa:** entre o IP e o usuário existem DHCP, NAT, VPN e proxy, e cada elo tem seu log e seu horário.
- **TCP** conta a história pela sequência de flags: o primeiro SYN diz quem iniciou; RST e SYN sem resposta revelam portas fechadas, filtradas e varreduras.
- **UDP** é rápido, sem estado e forjável: atenção a DNS, NTP e QUIC.
- **ICMP** serve para diagnóstico e também para descoberta e tunelamento.
- A porta indica o serviço **esperado**; o que importa é o abuso típico e a evidência de cada protocolo.
- **Firewall** é controle e sensor; allow inesperado costuma preocupar mais que deny.
- **Proxy** liga navegação a usuário; **VPN** com credencial válida não é sinônimo de usuário legítimo.
- **Wireshark** se usa com método: estatísticas primeiro, filtros depois, conteúdo por último, tudo documentado.

Respostas comentadas — exercícios da Parte 2

Exercício 1. Iniciou `192.168.5.20` (primeiro SYN). O serviço provável é **Microsoft SQL Server** (1433). Com apenas SYN e SYN-ACK, a conexão **ainda não completou**: falta o ACK do cliente. Se ele não vier e o cliente enviar RST, é o padrão de varredura SYN (half-open).

Exercício 2. Provavelmente não. 445 é a porta do serviço SMB; 52110 é efêmera. O mais provável é que a estação `10.10.0.66` tenha conectado ao SMB do servidor, e o log mostrado seja de um pacote de **resposta**. Confirmar pelo log de sessão do firewall (que registra o iniciador), pelo primeiro SYN ou pelo EDR. Atenção: se a estação fosse a 10.10.0.66 do PCAP de desafio, isso se encaixaria na varredura dela.

Exercício 3. `SF`: conexão estabelecida e encerrada normalmente. `REJ`: SYN respondido com RST (porta fechada, host vivo). `S0`: SYN sem nenhuma resposta (porta filtrada ou host inexistente). Muitos REJ e S0 da

mesma origem para muitas portas ou hosts em pouco tempo é o retrato de uma varredura; alguns SF no meio indicam portas encontradas abertas.

Exercício 4. Porque UDP não tem handshake nem confirmação. Não existe um "ESTABLISHED" ou flag que prove aceitação. É preciso procurar respostas no sentido inverso (ex.: resposta DNS), olhar a aplicação ou o comportamento posterior. Ausência de resposta pode significar porta aberta que não respondeu, filtro ou host inexistente.

Exercício 5. TTL 63 sugere TTL inicial 64 (Linux, macOS ou equipamento similar) com **um salto** de roteador no caminho. É apenas uma pista: o TTL inicial pode ser alterado.

Exercício 6. (a) RDP, TCP 3389, Event ID **4625** (falhas) e **4624** com **Logon Type 10** no host de destino. (b) SMB, TCP 445, **4624 Logon Type 3** e **5140/5145** (acesso a ADMIN$/C$), frequentemente seguido de **7045** (serviço criado). (c) Kerberos, porta 88, **4769** no controlador de domínio, com volume anormal de tickets de serviço e cifra RC4 (0x17).

Exercício 7. Chama atenção a **assimetria**: 3,2 GB enviados contra 20 MB recebidos, por 2 horas, de uma estação. Navegação baixa mais do que envia. Próximos passos: identificar host e usuário; descobrir o processo no EDR; enriquecer o destino (domínio via SNI/DNS, ASN, reputação, se é serviço de armazenamento); verificar se é backup ou sincronização autorizada; buscar outros hosts falando com o mesmo destino. Sem justificativa de negócio, escalar como possível exfiltração.

Exercício 8. Forward proxy fica na saída e intermedeia os usuários acessando a internet (controla e registra navegação). Reverse proxy fica na frente dos servidores e intermedeia os clientes que acessam a aplicação. O `X-Forwarded-For` é essencial no **reverse proxy** (e CDNs/balanceadores): o servidor interno vê o IP do proxy, e o IP real do cliente fica nesse cabeçalho.

Exercício 9. `certutil` é uma ferramenta legítima do Windows para certificados, mas é abusada para **baixar arquivos** e decodificar Base64 (técnica conhecida de "living off the land"). Um download de `.txt` de um IP sem domínio, por esse user-agent, numa estação de usuário, é um forte indício de execução de comandos maliciosos. Próximo passo: EDR para ver o processo pai, a linha de comando e o que foi feito com o arquivo.

Exercício 10. Usuário (é ele? conta ativa?); IP público (ASN, reputação, VPS/Tor); geolocalização e viagem impossível; MFA (aprovado, quantas tentativas, método novo); dispositivo (gerenciado? hostname/certificado); horário e duração comparados ao histórico; falhas anteriores do mesmo IP (contra ele e outras contas); atividade do IP atribuído na rede interna; volume transferido.

Exercício 11. (a) `ip.addr == 10.10.0.45`. (b) `tcp.flags.syn == 1 && tcp.flags.ack == 0`. (c) `dns.flags.rcode == 3`. (d) `http.request.method == "POST"`.

Exercício 12. `tcpdump -nn -r caso.pcap port 53` (ou `udp port 53` para apenas UDP).

Respostas dos desafios com PCAP

P1. 279 pacotes. Primeiro pacote em **10/10/2026 02:00:00 UTC**, que corresponde a **09/10/2026 23:00:00** em horário de Brasília (UTC−3). A captura dura cerca de 18 segundos. Lição: registre sempre o fuso ao documentar; "02:00" e "23:00" são o mesmo instante.

P2. Hostname **NB-FIN-042** (opção 12 no Discover/Request), MAC **3c:52:82:11:22:33**. O servidor `10.10.0.10` entregou máscara 255.255.255.0, gateway **10.10.0.1**, DNS **10.10.0.53** e lease de 28.800 s (8 h).

P3. Consultou **portal.empresa.example**, que resolveu para **203.0.113.80**. Antes, fez ARP pelo gateway. A conexão para a porta **443** completou o handshake (SYN, SYN-ACK, ACK), trocou dados e encerrou com FIN. Porta de origem **51523**. Comportamento normal: serve como linha de base.

P4. O host **10.10.0.45** enviou um **POST /login** para **intranet-legada.empresa.example** (`198.51.100.200`, porta **80**, HTTP sem TLS). Corpo: `usuario=ana.lima&senha=Primavera%402026`, ou seja, usuário **ana.lima** e senha **Primavera@2026** (`%40` é `@` codificado em URL). A resposta foi **302 Found** com `Set-Cookie: SESSIONID=...` e redirecionamento para `/home`, indicando **login bem-sucedido**. Achado de segurança: aplicação aceitando credenciais em texto claro. Recomendação: migrar para HTTPS e considerar a senha exposta (troca conforme processo).

P5. O host **10.10.0.66** enviou **20** Echo Request para `10.20.0.1` a `10.20.0.20` em menos de 1 segundo. **4** responderam: **10.20.0.1, 10.20.0.10, 10.20.0.11 e 10.20.0.12** (TTL 127, sugerindo Windows a um salto). Isso é **descoberta de hosts** (ping sweep).

P6. Em seguida, o mesmo **10.10.0.66** enviou **48 SYN** para portas diferentes de **10.20.0.10**, um dos hosts que respondeu ao ping. Portas **abertas** (responderam SYN-ACK): **22, 80, 445 e 3389**. As demais responderam RST-ACK (fechadas). Após cada SYN-ACK, o scanner respondeu com RST: padrão de **SYN scan (half-open)**. Sequência ping sweep → port scan no host vivo é reconhecimento clássico.

P7. Sim. Depois de o gateway legítimo responder com **00:1b:21:aa:00:01**, o MAC **b8:27:eb:66:66:66** enviou **6 ARP replies gratuitos** afirmando que `10.10.0.1` está nele. O OUI **b8:27:eb** pertence à Raspberry Pi Foundation. É o mesmo MAC do host `10.10.0.66`, que fez as varreduras. Forte indício de dispositivo não autorizado realizando reconhecimento e tentativa de **man-in-the-middle**.

P8. O host **10.10.0.91** recebeu **44** respostas **NXDOMAIN** para nomes aleatórios em `.top`, `.info`, `.biz`, `.xyz` e `.net`. **Um** domínio resolveu: **qmzvtrkpwlx.top → 192.0.2.66**, e logo depois o host **completou um handshake TCP** com `192.0.2.66:443`. Padrão de **DGA** seguido de contato com possível C2.

P9. O host **10.10.0.120** fez **15** consultas **TXT** para subdomínios de **t.dados-sync.example**, cada uma com um rótulo de 50 caracteres em Base32 e um contador sequencial (`000`, `001`, ...). Decodificando os primeiros rótulos (Base32), aparece o texto `relatorio_folha_pagamento_outubro_2026.xlsx|` seguido de dados binários. É **DNS tunneling para exfiltração**: o nome de um arquivo sensível de RH saindo pela resolução de nomes. Para decodificar: concatene os rótulos na ordem do contador, converta para maiúsculas, complete com `=` até um múltiplo de 8 caracteres e use `base32 -d` (Linux) ou `base64.b32decode()` no Python. Faça isso no seu laboratório, nunca colando dados de um caso real em decodificadores online.

P10. Timeline (UTC, 10/10/2026; subtraia 3 h para Brasília): **02:00:00.010** (frames 1–4) DHCP entrega 10.10.0.87 a NB-FIN-042 — normal → **02:00:00.98** (frames 9–16) NB-FIN-042 acessa portal.empresa.example via HTTPS — normal → **02:00:01.194** (frame 22) 10.10.0.45 faz login HTTP em claro como ana.lima — risco, credencial exposta → **02:00:01.305–01.879** (frames 27–50) 10.10.0.66 (Raspberry Pi) faz ping sweep em 10.20.0.1–20 → **02:00:01.883–02.121** (frames 51–150) SYN scan em 10.20.0.10, encontrando 22/80/445/3389 → **02:00:04.121–14.121** (frames 151–156) o mesmo dispositivo anuncia ser o gateway via ARP falso → **02:00:14.18–16.82** 10.10.0.91 recebe 44 NXDOMAIN e às **02:00:16.871** (frames 247–249) completa handshake com 192.0.2.66:443 — DGA/C2 → **02:00:17.022–**

17.862 (frames 250–278) 10.10.0.120 exfiltra dados via 15 consultas TXT para t.dados-sync.example. **Escalar imediatamente:** o dispositivo 10.10.0.66 (reconhecimento + tentativa de MitM na LAN), o host 10.10.0.91 (possível infecção com C2) e o host 10.10.0.120 (exfiltração de dados de RH). **Registrar e recomendar:** a aplicação com login em HTTP e a troca da credencial de ana.lima conforme processo. **Benigno:** a atividade de NB-FIN-042, que serve de linha de base.

Próximo módulo

Módulo 2 — Arquitetura de Ambientes Corporativos. Com redes dominadas, vamos montar o quebra-cabeça: Internet, roteador, firewall, DMZ, LAN, VLANs, servidores, Active Directory, DNS, proxy, VPN, WAF, balanceador, EDR e SIEM, com diagramas completos. O objetivo é olhar para qualquer arquitetura e responder: **onde estão os logs, quem enxerga essa comunicação, o que pode bloquear e o que pode detectar**.